



Zero Trust i isolerade komplexa miljöer

System- och nätverksdesign utifrån Försvarsmaktens KSF

Zero Trust in isolated complex environments
System and Network Design from Försvarsmaktens KSF

Oskar Alfredsson

Fakulteten för hälsa, natur-och teknikvetenskap

Datavetenskap

C-uppsats 15hp

Handledare: Martin Blom

Examinator: Johan Eklund

Datum: 2026-06-01

“Never trust, always verify.”

— John Kindervag

Sammanfattning

I takt med att cyberattacker mot försvarsrelaterade organisationer ökar globalt räcker inte längre traditionella slott-och-vallgravsfilosofin till, så efterfrågan av isolerade miljöer ökar i samma takt. I denna uppsats undersöks hur Zero Trust-principer och Försvarsmaktens Krav på Säkerhetsfunktioner (KSF) kan tillämpas i en isolerad komplex miljö, med målet att ta fram en system- och nätverksarkitektur som uppfyller dessa krav. Designen bygger på separerade nätverkszoner med en central knutpunkt, samt utplacerade verkställighetspunkter (enforcement punkter) som kommunicerar med en central beslutsfattande komponent som kan dynamiskt fatta beslut i real-tid baserad på händelser i IT-systemet. Designen uppfyller KSF:s krav inom behörighetskontroll, intrångsdetektering, intrångsskydd och säkerhetsloggning, och slutsatsen är att Zero Trust och KSF kan tillämpas i en isolerad komplex miljö.

Abstract

As cyberattacks against defense-related organizations increase globally, the traditional castle-and-moat philosophy is no longer sufficient, so the demand for isolated environments increases at the same rate. This paper examines how Zero Trust principles and Försvarsmaktens Security Function Requirements (Krav på säkerhetsfunktioner; KSF) can be applied in an isolated complex environment, with the goal of developing a system and network architecture that meets these requirements. The design is based on separated network zones with a central hub, as well as deployed enforcement points that communicate with a central decision-making component that can dynamically make decisions in real-time based on events in the IT system. The design meets the KSF's requirements within authorization control, intrusion detection, intrusion protection and security logging, and the conclusion is that Zero Trust and KSF can be applied in an isolated complex environment.

Innehåll

Sammanfattning	iii
Abstract	v
Figurer	xiv
Tabeller	xv
1 Introduktion	1
1.1 Bakgrund	2
1.1.1 Isolerade miljöer	2
1.1.2 Traditionella Säkerhetsfilosofier	2
1.1.3 Zero Trust	3
1.2 Problembeskrivning	3
1.3 Syfte och mål	4
1.4 Etik och samhälle	4
1.4.1 Övervakning	4
1.4.2 Ansvarstagande	4
1.5 Metod	5
1.6 Uppdragsgivare	5
1.7 Avgränsningar	5

1.7.1	Fjärruppdatering av programvaremekanismer av Oliver Weberg	6
1.7.2	AI/LLM:er för hantering av logganalys av Hugo Kindstedt . . .	6
1.7.3	Röjande Signaler (RÖS) och Signalskydd	6
1.8	Begrepp och definitioner	7
1.9	Disposition	10
2	Bakgrund	11
2.1	KSF	11
2.1.1	Konsekvensnivå	12
2.1.2	Exponeringsnivå	12
2.1.2.1	Exponering från personer	12
2.1.2.2	Exponering från informationsutbyte	12
2.1.3	Kravnivå	12
2.2	Zero Trust	13
2.2.1	Least privilege	13
2.2.2	Always verify	14
2.2.2.1	mTLS	14
2.2.3	Assume breach	15
2.3	Tidigare arbeten inom Zero Trust	15
2.3.1	Build Security Into Your Network's DNA: The Zero Trust Network Architecture	15
2.3.2	NIST 800-207: Zero Trust Architecture	21
2.3.2.1	Device Agent/Gateway Model	25
2.3.2.2	Resource Portal Model	26
3	Analys	27
3.1	Tolkning av KSF	27
3.2	Funktionella säkerhetskrav	28

3.2.1	Gemensamma krav; SFGK_FEL	28
3.2.2	Behörighetskontroll; SFBK_AUT, SFBK_ÅTK	29
3.2.3	Intrångsdetektering; SFID_DAT, SFID_ANA	30
3.2.4	Intrångsskydd; SFIS_INT, SFIS_KIN, SFIS_KUT	31
3.2.5	Säkerhetsloggning; SFSL_REG, SFSL_SKY, SFSL_ANA	31
3.3	Analys av Kindervag's Zero Trust modell	33
3.3.1	Komplexitet	33
3.3.2	Skalbarhet	34
3.3.3	Tredje Part Implementeringar	35
3.4	Analys av NIST Publikation 800-207	35
3.4.1	Control Plane och Data Plane	35
3.4.2	Device Agent/Gateway Model	35
3.4.3	Resource Portal Model	36
3.4.4	Angrepp mot PDP	36
4	Design	39
4.1	Designprinciper	39
4.1.1	Isolerad miljö	39
4.1.2	Segmentering	40
4.1.3	Modularitet	41
4.1.4	Skalbarhet	42
4.1.5	Data/Control Plane	44
4.2	Specifikationer och Krav	45
4.2.1	Zero Trust	45
4.2.2	KSF-krav mappade mot designval	46
4.3	System- och Nätverksarkitektur	48
4.3.1	Komponenter	48
4.3.2	Zonstruktur	50

4.3.3	Resource- eller Device Agent Gateway model?	51
4.3.4	Kommunikationsflöden	51
4.3.5	Control/Data Plane i nätverket	54
5	Resultat	57
5.1	Kommunikationsflöden	58
5.1.1	Initierande trafik	58
5.1.2	Styrande- och Applikationsdata	59
5.2	Nätverkstopologi	61
5.3	Zon-Struktur	63
5.4	Segmentation Gateway	64
5.5	Agentstruktur	65
5.6	PKI certifikat delegering	66
6	Slutsats	67
6.1	Diskussion	67
6.1.1	KSF-kravuppfyllnad	67
6.1.2	Always Verify	72
6.1.3	Least Privilege	73
6.1.4	Assume Breach	73
6.1.5	Svagheter, Risker och Begränsningar	74
6.2	Slutsats	75
6.3	Vidare arbete	75
6.3.1	PoC	75
6.3.2	Tolka System-av-System enligt KSF	76
6.3.3	PKI och offline certifikatutfärdare	76
	Litteraturförteckning	78

<i>INNEHÅLL</i>	xi
Bilagor	81
A Bilagor från KSF	83
A.1 Tabell för konsekvensnivå	83
A.2 Tabell för exponeringsnivå	86
A.3 Tabell för kravnivå	87
A.4 Kravstruktur	88
A.5 Funktionella säkerhetskrav	88
A.5.1 Tabell för Funktionella Säkerhetskrav	88

Figurer

2.1	Hur mTLS fungerar; från Cloudflare. [1]	14
2.2	Gårdagens nätverk[2]	16
2.3	Gårdagens nätverk som implementerar säkerhetsfunktioner[2]	17
2.4	Segmentation Gateway[2]	18
2.5	Exempel på hur Kindervag's säkerhetsmodell kan implementeras [2]	19
2.6	Kindervag's säkerhetsmodell med DAN MCAP	20
2.7	Logiska Kärnkomponenter i Zero Trust, från NIST [3]	21
2.8	Trust Algorithm Input	24
2.9	Device Agent/Gateway Model[3]	25
2.10	Resource Portal Model[3]	26
4.1	Skalbar Site-to-Site lösning	43
4.2	Logisk Struktur för Application Perimeter	50
5.1	Ikoner som används i diagrammen	57
5.2	Initierande trafikflöde	58
5.3	Abstrakt vy av Styrande- och Applikationsdata	59
5.4	Detaljerad vy av Styrande- och Applikationsdata	60
5.5	Nätverkstopologi	62
5.6	Zon och Edge Gateway	63
5.7	Segmentation Gateway	64

5.8	Agentstruktur för Konventionella och Okonventionella system	65
5.9	PKI certifikat delegering	66
A.1	Exempel på kravidentifiering utifrån KSF[4]	88

Tabeller

1.1	Relevanta begrepp och ordlista	10
2.1	Komponenterna i NIST ZTA	23
4.1	Funktionella säkerhetskrav kopplade mot designval	47
4.2	Komponenter i System och Nätverksdesign	49
6.1	Uppfyllda Gemensamma KSF krav	67
6.2	Uppfyllda Behörighetskontroll KSF krav	68
6.3	Uppfyllda Intrångsdetektering KSF krav	69
6.4	Uppfyllda Intrångsskydd KSF krav	70
6.5	Uppfyllda Säkerhetsloggning KSF krav	71
A.1	Bedömning av konsekvens enligt femgradig skala; Konsekvensnivå från KSF[4]	85
A.2	Exponeringsnivåer med tillhörande kriterier; Exponeringsnivåer från KSF[4]	87
A.3	Fastställning av kravnivå; Kravnivå från KSF[4]	87
A.4	Alla funktionella säkerhetskrav från KSF[4]	90

Kapitel 1

Introduktion

I dagens samhälle är näst intill all elektronik sammankopplat på ett eller annat sätt, genom det metaforiska spindelnät vi kallar internet. Detta skapar möjligheter som att kunna kommunicera med vem som helst, när som helst, med vad som helst. För en vanlig individ är detta nödvändigtvis inget problem, men för företag eller myndigheter där ett intrång till IT-miljö skulle riskera rikets säkerhet är det en annan sak. Problematiken i att allt är sammankopplat är just att allt är sammankopplat. I Europa under perioden mellan Januari 2025 och Januari 2026 så sågs det en ökning med 17% av antalet cyberattacker mot olika organisationer och myndigheter, samt en ökning på 33% inom flyg och försvarssektorn runtom i världen [5]. På grund av geopolitik och tillgången till hjälpmedel som AI så finns det inte mycket som tyder på att antalet angrepp kommer minska. Majoriteten av angrepp förekommer i form av distansattacker via internet, just på grund av tillgängligheten och enkelheten i att allt är sammankopplat. Därför kan det vara fördelaktigt, i vissa situationer, att isolera den interna infrastrukturen från internet för att minska attackytan. Det kan också finnas situationer där det inte finns någon möjlighet att koppla upp sig mot internet, exempelvis i krigssituationer. Men finns det fortfarande problematiken med interna angrepp, där angriparen har tillgång till den fysiska infrastrukturen. Dessa angrepp kan oftast elimineras av Zero Trust modellen.

1.1 Bakgrund

1.1.1 Isolerade miljöer

En isolerad miljö bryter den största attackytan, åtkomsten till internet, genom att kräva fysisk åtkomst för att kunna attackera infrastrukturen. Detta i sig gör inte IT-system 100% säkra, det som händer är i själva verket att antalet angrepp minskar samt minimerar vilka typer av angrepp som man skulle kunna förvänta sig. Med ett isolerat IT-system medför det att den enda attackytan som finns är att angriparen har tillgång till nätverket eller IT-systemet på något fysiskt sätt, här måste man applicera säkerhetsprinciper som kan säkerställa att nätverk och IT-system inte blir utsatta av interna angrepp.

1.1.2 Traditionella Säkerhetsfilosofier

Traditionella säkerhetsfilosofier bygger på en slott-och-vallgrav filosofi, där det är svårt att få åtkomst till slottet genom en bra yttre "vallgrav"/säkerhet. Men bristen ligger i att om en angripare redan finns inuti slottet så spelar inte den yttre säkerheten någon roll[6]. Denna typ av filosofi bygger på att man har någon form av tillit till den interna IT-miljön, vilket inte går att applicera i situationer där miljön anses vara kritisk, alltså att det finns anledningar att angripa miljön, oberoende av hur svårt det är att angripa den. På grund av den säkerhetsnivå som ställs på dessa typer av IT-system, så är det relevant och intressant att utveckla dessa utifrån Försvarmaktens Krav på Säkerhetsfunktioner (KSF), tillsammans med Zero Trust principer.

1.1.3 Zero Trust

Zero Trust är ett modernare koncept inom cybersäkerhet, där konceptet bygger på att man har som utgångspunkt att inte lita på någon eller något [2, 6]. Zero Trust bygger på tre grundprinciper;[7]

- *Always verify*: Verifiera kontinuerligt användare och system.
- *Least privilege*: Ge enbart de privilegier som behövs till användare och system.
- *Assume breach*: Anta att någon har angripit infrastrukturen.

1.2 Problembeskrivning

I en osäker tid där andelen cyberattacker har ökat drastiskt så finns det stor efterfrågan om IT-system där hög säkerhetsnivå går att uppnå. Då företag som Saab, som denna uppsats görs tillsammans med, utvecklar produkter som kan innehålla försvarssekretess, företagssekretess, exportkontrollerad information, eller annan känslig information. Detta gör att IT-systemet måste skyddas mot cyberhot, vilket gör det ytterst viktigt att IT-system uppnår en viss säkerhetsnivå. Denna uppsats kommer då fungera som en grund till vidare arbete inom området. För att uppnå den önskade säkerhetsnivån är det viktigt att applicera moderna säkerhetsprinciper men även följa bevisat säkra ramverk, därför kommer denna uppsats försöka besvara frågan:

Hur applicerar man Zero Trust principer och Försvarmaktens KSF i en isolerad komplex miljö?

1.3 Syfte och mål

Syftet med detta arbete är att undersöka om och hur man kan applicera Zero Trust principer och Försvarmaktens KSF i en isolerad komplex miljö. Målet med detta projekt är att designa ett IT-systemarkitektur och nätverksarkitektur som implementerar Zero Trust principer samt också uppfyller kraven som ställs från Försvarmakten på IT-system. Resultatet av detta arbete kommer kunna användas som ett underlag och ramverk för framtida utveckling av IT-system.

Något att påpeka är att syftet med denna uppsats är inte att följa IT-systems specifikationen (ITSS) struktur och obligatoriska element som beskrivs i KSF, detta görs vid konstruktion av kravspecifikation vid utveckling av produkt.

1.4 Etik och samhälle

1.4.1 Övervakning

Tekniken i detta arbete kommer att inkludera exempel på övervakning av olika system och användare, detta kan ses som inkräktande på individers integritet. Syftet är att övervakningen kommer ske i form av automatisk respons hantering beroende på situation. Övervakningen kommer inte ske direkt av någon människa, men det kan behövas mänsklig hantering ifall olika övervakningssystem skulle agera på *false positives*^{1.1}. Meningen bakom övervakningen är inte att diskriminera personen som använder systemet, utan att kunna uppfylla den säkerhetsnivå som ställs på dessa typer av IT-system.

1.4.2 Ansvarstagande

Mycket av IT-systemen kommer agera självständigt, vilket innebär att beslut fattas av systemen själva. På grund av detta kan olika system agera på *false positives*, detta kan

orsaka att tillgängligheten i IT-systemet kan minska på grund av låsta system. Då detta görs automatiskt är det svårt att lägga ansvaret på missat arbete utförd i dessa system på någon specifik individ.

1.5 Metod

Detta arbete kommer utföras som en litteraturstudie, detta görs genom att kolla på redan existerande systemarkitektur och tekniker, men även artiklar och studier som diskuterar Zero Trust i praktiken. Jag kommer även korsreferera detta med KSF för att analysera på vilken säkerhetsnivå vissa delar av systemet skulle uppnå för att kunna svara på frågan som denna uppsats ställer sig.

1.6 Uppdragsgivare

Saab AB är ett svenskt flyg- och försvarsföretag som huvudsakligen verkar från Sverige. Cyber Security-teamet, som är projektägare, behöver hitta nya lösningar på cybersäkerhetsfrågor som uppstår vid utformningen av nya produkter. Problemområdet som undersöks i denna uppsats, handlar om hur teamet kan utforma system som säkerställer att användarna endast har tillgång till de delar av systemet som är auktoriserade för och att alla användare är autentiserade på rätt sätt, samt ta fram system som säkerställer ett robust skydd mot cyber relaterade hot.

1.7 Avgränsningar

Det förekommer ytterligare två uppsatser som kommer skrivas parallellt med denna uppsats, dessa är skriva av Hugo Kindstedt och Oliver Weberg. Dessa uppsatser görs också på uppdrag av Saab och cybersäkerhetsgruppen.

1.7.1 Fjärruppdatering av programvaramekanismer av Oliver Weberg

Webergs uppsats handlar om hur man kan applicera mekanismer för fjärruppdateringar av programvara i olika IT-system. Uppsatsen och arbetet kommer kunna medföra att mjukvara i isolerade system kommer kunna få de säkerhetsuppdateringar som gör att IT-system fortsatt kan vara säkert. Avgränsningarna som kommer då ske i min uppsats är ett antagande att mjukvara kan få de säkerhetsuppdateringar som krävs för att fortsätta hålla IT-system säkra.

1.7.2 AI/LLM:er för hantering av logganalys av Hugo Kindstedt

Kindstedt uppsats kommer undersöka möjligheterna att applicera AI/LLM:er för att kunna analysera loggar (1.1). Kindstedts arbete kommer kunna användas för att övervara de eventuella säkerhetsloggar som medförs av Zero Trust principer. Avgränsningar som kommer påverka detta arbete är minimala, då Kindstedts arbete bygger på en mer teknisk nivå kring loggning och analys av loggar av AI modeller. Skillnaden blir att min uppsats kommer fokusera mer på vad som borde loggas, inte hur loggarna kommer användas för analys på en teknisk nivå.

1.7.3 Røjande Signaler (RÖS) och Signalskydd

Ett krav från de funktionella säkerhetskraven i KSF kräver att system följer regelverket för 2006-03-24 10:755.65114 *Beslut om krav på skydd mot røjande signaler (RÖS)*. I en verklig implementation där säkerhetsklassas information ska överföras över elektroniska enheter borde detta regelverket och kravställningen från KSF följas, men denna uppsats kommer inte diskutera detta då det är utanför kunskapsområden för denna uppsats. Detta gäller även Signalskydd, även om lösningen kring signalskydd bygger på kryptering så förekommer denna lösning i andra tolkningar och krav.

1.8 Begrepp och definitioner

Denna sektion handlar om relevanta begrepp och definitioner som används i denna uppsats. En del begrepp och definitioner kommer från Försvarsmaktens KSF, detta är för att kunna förhålla sig och minimera förvirringar mellan dessa dokument.

Term	Definition
Attributbaserad åtkomstkontroll	<i>Attribute-Based-Access-Control/ABAC</i> ; Åtkomstkontroll som utgår ifrån attributer i ett system eller användare (e.g tid eller plats) för att tillåta åtkomst till resurser eller system, kan ge mer flexibilitet i hur man ger ut åtkomst till resurser. [8]
Brandvägg	En säkerhetsfunktion i ett nätverk som övervakar och filtrerar inkommande och utgående nätverkstrafik utifrån fördefinierade regler, i syfte att skydda ett nätverk eller system mot obehörig åtkomst.
Cybersäkerhet	Cybersäkerhet är konsten att skydda nätverk, enheter och data från obehörig åtkomst eller kriminell användning och att säkerställa informationens konfidentialitet, integritet och tillgänglighet. [9]
Endpoint	En knutpunkt mellan två olika system där de kan kommunicera med varandra.
Enhet	(Device) Hårdvara eller mjukvara som är ansluten till ett IT-system och som kan initiera eller ta emot kommunikation, exempelvis en dator, server eller nätverkskomponent.

Term	Definition
False Positive	En term inom cybersäkerhet som säger att en händelse har fångats upp av något typ av övervakningssystem, men händelsen i själva verket behöver inte ha någon negativ inverkan, kan ses som ett <i>misstag</i> eller <i>bättre att få med mer händelser än för lite</i> .
Funktionella säkerhetskrav	De krav i KSF som ska implementeras av IT-systemet dess operativa miljö eller båda i samverkan för att uppfylla säkerhetsmålen [4].
Gateway	En komponent som möjliggör trafik att flöda från ett segment till ett annat.
IT-system	Ett system med teknik som hanterar och utbyter information med omgivningen, i KSF används oftast ordet system synonymt med IT-system [4].
KSF	Försvarsmaktens <i>Krav på säkerhetsfunktioner (KSF)</i> är en samling av krav och metodiker som används vid specificering och utveckling av IT-system som ska användas av Försvarsmakten [4].
Komplexitet	Graden av svårighet att förstå, förutsäga eller hantera ett systems beteende, ofta till följd av ett stort antal komponenter, beroenden och interaktioner.
Komplex Miljö	Ett sammanhang där ett stort antal olika typer av IT-system samverkar på komplexa och oförutsägbart sätt.
LAN	<i>Local Area Network</i> ; Ett lokalt nätverk som förbinder enheter inom ett begränsat geografiskt område, exempelvis ett kontor eller en byggnad, och möjliggör kommunikation och resurdelning mellan dessa.

Term	Definition
Lateral Movement	Är en angrepps metod som bygger på att eskalera privilegier uppåt i IT-systems hierarki för att åstadkomma de mål som de är ute efter. Detta kan vara att gå från att angripa en användares konto till administratör/root.
Logg	(Kontinuerligt) insamlad information om de operationer som utförs i ett system [4].
Mikrosegmentering	Mikrosegmentering är en säkerhetsmetod som bygger på att isolera miljöer (datacenter, cloud miljöer etc) i zoner för att enklare kunna begränsa och kontrollera åtkomsten [10].
Resurs	En tjänst, datamängd, applikation eller annan tillgång i ett IT-system som ett subjekt kan begära åtkomst till.
Rollbaserad åtkomstkontroll	<i>Role-Based-Access-Control/RBAC</i> ; Åtkomstkontroll som utgår ifrån i vilken eller vilka roller som en användare kan utnyttja ett system [4, 11].
Subjekt	En entitet i ett IT-system som kan utföra en åtgärd. Ett subjekt kan t.ex. vara IT-systemets representation av en användare, en process eller en dator [4].
Tillgänglighet	Skyddsmål där informationstillgångar ska kunna utnyttjas i förväntad utsträckning och inom önskad tid [4].
VLAN	<i>Virtual Local Area Network</i> ; En logisk uppdelning av ett fysiskt nätverk i separata virtuella segment, vilket möjliggör isolering av trafik och ökad säkerhet utan krav på separat fysisk infrastruktur.

Term	Definition
Zon	En logiskt eller fysiskt avgränsad del av ett nätverk med gemensamma säkerhetskrav och åtkomstregler. Zoner används för att separera resurser och begränsa lateral rörelse mellan olika delar av systemet.
Åtkomstkontroll	<i>Access Control</i> ; Funktioner i ett system som syftar till att reglera och kontrollera en användares åtkomst till olika resurser [4].

Tabell 1.1: Relevanta begrepp och ordlista

1.9 Disposition

1. Introduktion: Introducerar ämnen och ger grundläggande bakgrund och förståelse till resterande av rapporten.
2. Bakgrund: Presenterar KSF och dess kravstruktur, de tre Zero Trust-principerna, samt en djupgående genomgång av Kindervags nätverksmodell och NIST SP 800-207 inklusive dess komponenter och modeller.
3. Analys: Tolkar KSF-krav utifrån ett nätverksperspektiv, analyserar styrkor och svagheter i Kindervags modell och NIST 800-207.
4. Design: Specificerar de krav som Zero Trust-principerna och KSF ställer på systemet, och beskriver hur dessa realiserar konkret i system- och nätverksarkitekturen.
5. Resultat: Presenterar de färdiga system- och nätverksdesigndiagrammen.
6. Slutsats: Diskuterar och reflekterar över resultatet i förhållande till frågeställningen, samt identifierar möjliga vidare arbeten.

Kapitel 2

Bakgrund

2.1 KSF

Försvarsmaktens KSF bygger på en rad olika assuranskrav och funktionella säkerhetskrav, dessa olika krav appliceras i IT-system för att kunna säkerställa att de når de krav som ställs på säkerhet hos Försvarsmakten. Vilka assuranskrav och funktionella säkerhetskrav som behövs implementeras bestäms utifrån en bestämd kravnivå (A.3), som i sig bygger på en viss bestämd konsekvensnivå (A.1) och exponeringsnivå (A.2). Varje krav kan också vara indelat i flera kravkomponenter, vilket beskriver funktionalitet som kravet ska uppfylla, detta varierar beroende på kravnivå då en högre kravnivå kan kräva striktare kravkomponenter. Varje krav samt kravkomponenter kommer inte presenteras i denna rapport, om förtydliganden kring vissa krav behövs hänvisas det till Försvarsmaktens KSF[4].

Notera att assuranskrav främst bygger på konstruktion av administrativa rutiner och dokumentation av IT-system. Denna uppsats fokuserar inte på dessa krav utan fokuset riktar sig mer mot den tekniska aspekten, alltså de funktionella säkerhetskraven, av den lösning som kommer presenteras i denna uppsats.

2.1.1 Konsekvensnivå

Konsekvensnivån som presenteras av KSF (A.1) bygger på en skala mellan 1 till 5, där 5 innebär störst konsekvens vid informationsläckage. Denna tabell används för att kunna fastställa vilken typ av säkerhetsklassning som kan appliceras på ett IT-system, utifrån ett informationsläckage.

2.1.2 Exponeringsnivå

För att redogöra exponeringen för IT-systemet så presenterar KSF en tabell för exponeringsnivån mot informationsutbyte och personer (A.2).

2.1.2.1 Exponering från personer

Exponering från personer innefattar den personal som är menad att få tillgång till IT-systemet, men även personer som tillfälligt skulle kunna vistas i samma lokal eller plats som systemet skulle används på.

2.1.2.2 Exponering från informationsutbyte

Informationsutbyte innefattar all dataöverföring mellan IT-system, detta skulle kunna vara i form av elektronisk kommunikationskanaler eller via flyttbara lagringsenheter. Försvarmaktens KSF påpekar också att säkerhetsuppdateringar samt uppdatering av säkerhetsfunktioners kontrollmekanismer (och deras styrande data t.ex antivirussignaturer) inte påverkar exponeringen av IT-system.

2.1.3 Kravnivå

Kravnivån bygger på en kombination av konsekvensnivån (A.1) och exponeringsnivån (A.2). Kravnivån används för att kunna fastställa vilka funktionella säkerhetskrav och

assuranskrav som måste implementeras i IT-systemet för att uppnå de kriterier och situationer som nämns i tabellerna för konsekvensnivå och exponeringsnivå.

2.2 Zero Trust

Zero Trust kan beskrivas som ett paraplybegrepp för: *Lita inte på någon eller något som utgångspunkt*. Det finns mer specifika termer som grundar sig i tekniken som den är riktad till. Zero Trust Networks (ZTN) är ett koncept som beskriver hur Zero Trust appliceras i ett nätverk, och Zero Trust Network Access (ZTNA) beskriver hur åtkomsten till nätverksbaserade tjänster kan använda Zero Trust. Idén bakom varje *gren* av Zero Trust bygger fortfarande på samma principer, men är applicerbar i olika situationer.

2.2.1 Least privilege

Least privilege eller *Minsta Privilegier* bygger på att användare, applikationer och system enbart ska ha tillgång till de absolut nödvändigaste resurserna och privilegierna som behövs för att kunna utföra det arbete som de behöver. Här används metoder som *Role Based Access Control (RBAC)* och *Attribute Based Access Control (ABAC)*. [7]

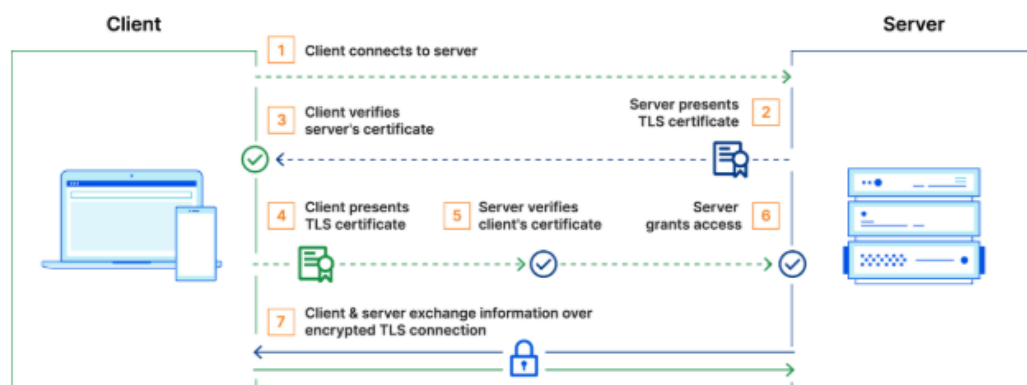
RBAC och ABAC appliceras primärt på användar-, system och applikationsnivå, men på nätverksnivå krävs det mikrosegmentering och strikta brandväggsregler. Mikrosegmentering och strikta brandväggsregler används för att dela upp nätverket i flera delar, detta är nödvändigt ifall man inte vill ha obehöriga som använder eller avlyssnar andra delar av nätverket som personen egentligen inte ska ha tillgång till [2]. Målet är att minimera all möjlig kommunikation mellan enheter till just det absolut nödvändiga för att motarbeta *lateral movement* (1.1). Detta minimera konsekvensnivån ifall någon enhet skulle bli övertagen av angripare.

2.2.2 Always verify

Always verify eller *Kontinuerlig verifiering* handlar om att användare, applikationer och system ska kunna påvisa vem de är om det efterfrågas. Detta kan göras via olika typer av inloggningsmetoder (lösenord och MFA), en annan metod är att använda certifikat från gemensamma tillförlitliga källor (Certificate authority/PKI), det är denna metod som används för att veta att användare kommunicerar med rätt webbsidor på internet (https med TLS). I Zero Trust miljöer används ofta certifikat för att kunna påvisa att användare, applikationer och system är vilka de påstår att de är [1]. Detta kan göras via mTLS som kräver att både användare och server påvisar certifikat innan de kan börja kommunicera med varandra.

2.2.2.1 mTLS

mTLS står för *mutual TLS* vilket är en metod för gemensam autentisering. Till skillnad från vanlig TLS där enbart servern behöver uppge certifikat, så behöver både server och subjekt visa varandra sina certifikat för att kunna upprätta en säker session. mTLS har fördelen att både kunna autentisera båda parterna i ett kommunikationsflöde, men även kunna sätta upp en krypterad TLS anslutning. [1]



Figur 2.1: Hur mTLS fungerar; från Cloudflare. [1]

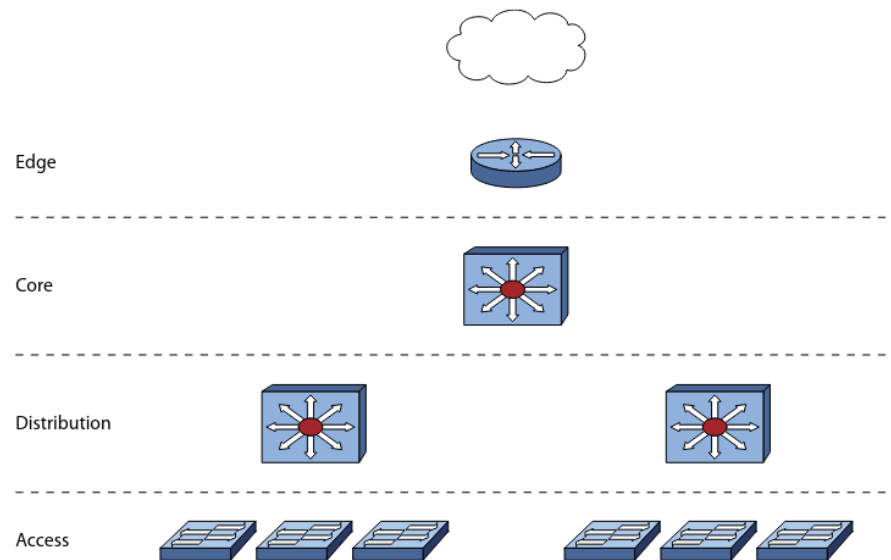
2.2.3 Assume breach

Assume breach eller *Förvänta intrång* skulle man kunna kalla efterarbetet i Zero Trust miljöer. Assume breach handlar om att man alltid övervakat nätverket och användare efter avvikelser som skulle kunna tyda på att något har blivit kapat eller att icke auktoriserade användare har kommit åt resurser. Assume breach handlar också om att man ska agera omgående om något skulle ske, exempelvis att isolera eventuella system efter avvikelser för att kunna minimera eventuella risker. [7]

2.3 Tidigare arbeten inom Zero Trust

2.3.1 Build Security Into Your Network's DNA: The Zero Trust Network Architecture

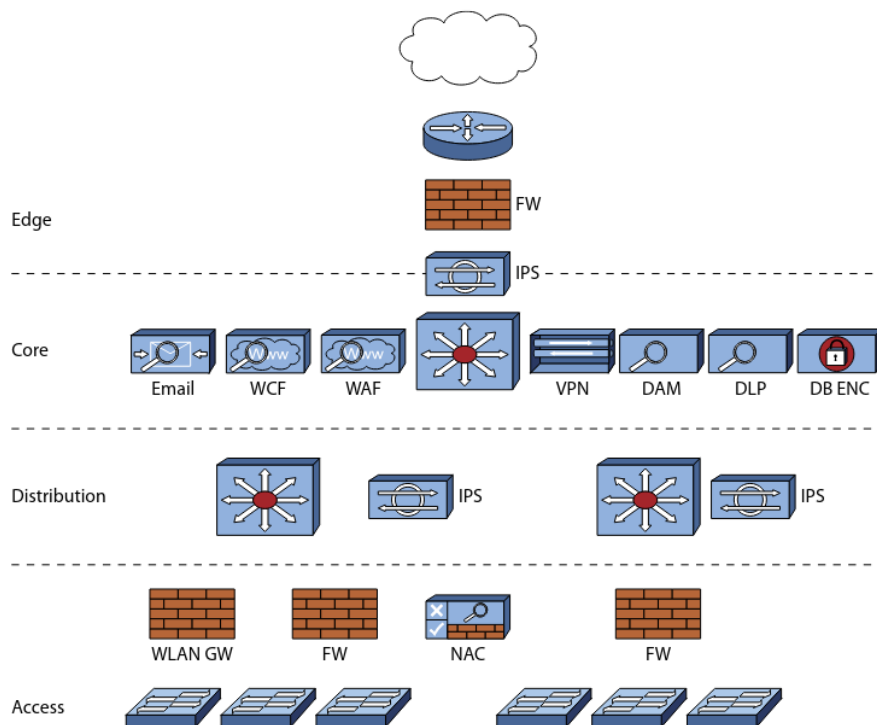
I artikeln *Build Security Into Your Network's DNA: The Zero Trust Network Architecture*[2] beskriver John Kindervag problemet med *gårdagens* nätverk. Han går in på hur *morgondagens* nätverk bygger på en modulär säkerhetsmodell som implementerar Zero Trust. Gårdagens nätverk, som Kindervag beskriver, byggde inte på att implementera säkerhetsfunktioner i grunden 2.2.



Figur 2.2: Gårdagens nätverk[2]

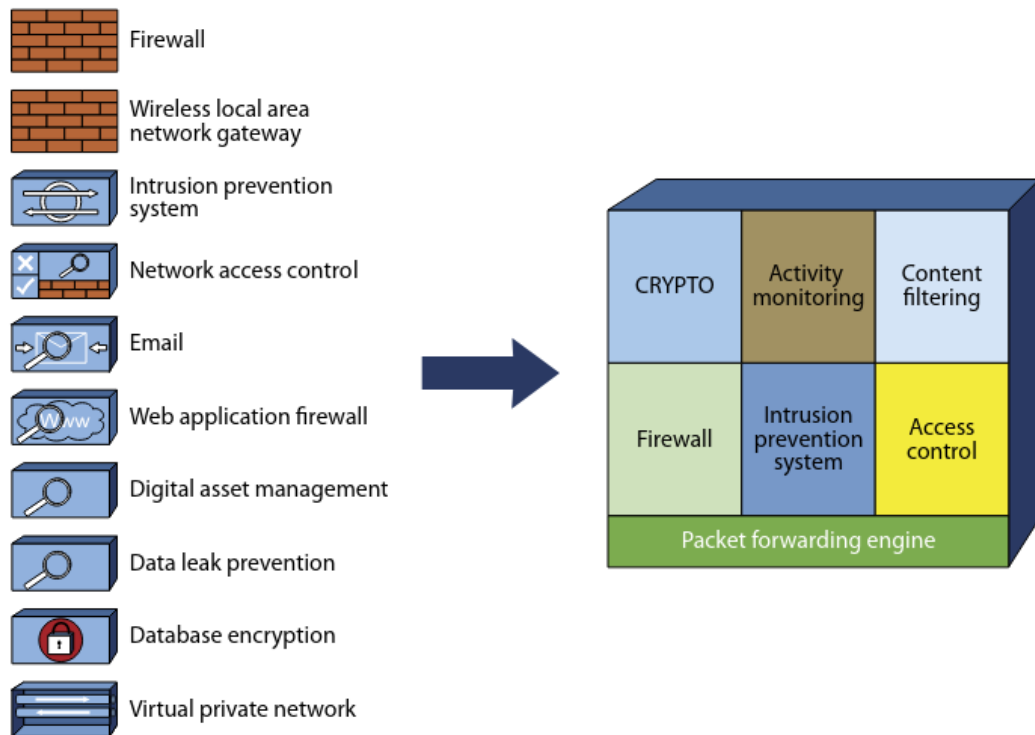
När säkerhetsmekanismer försökte att implementeras i existerande nätverket var det ytterst svårt att få det att fungera ihop på ett bra och smidigt sätt. Problematiken låg i att man försökte lappa ihop problemet i efterhand, vilket leder till att man försökte implementera säkerhetskontroller i ett etablerat nätverk, vilket i sig gör det svårt att göra det skalbart.

Figur 2.3 visar tydligt problemet med att implementera säkerhetsmekanismer i efterhand. Det förekommer flera duplicerade säkerhetsmekanismer i flera delar av nätverket, detta kan göra det extremt svårt att felsöka men även att göra detta skalbart på ett hållbart sätt. Denna typ av nätverk är just gjort för skalbarhet och smidighet, men implementeringen av säkerhetsmarginaler förvrider de originella fördelarna.



Figur 2.3: Gårdagens nätverk som implementerar säkerhetsfunktioner[2]

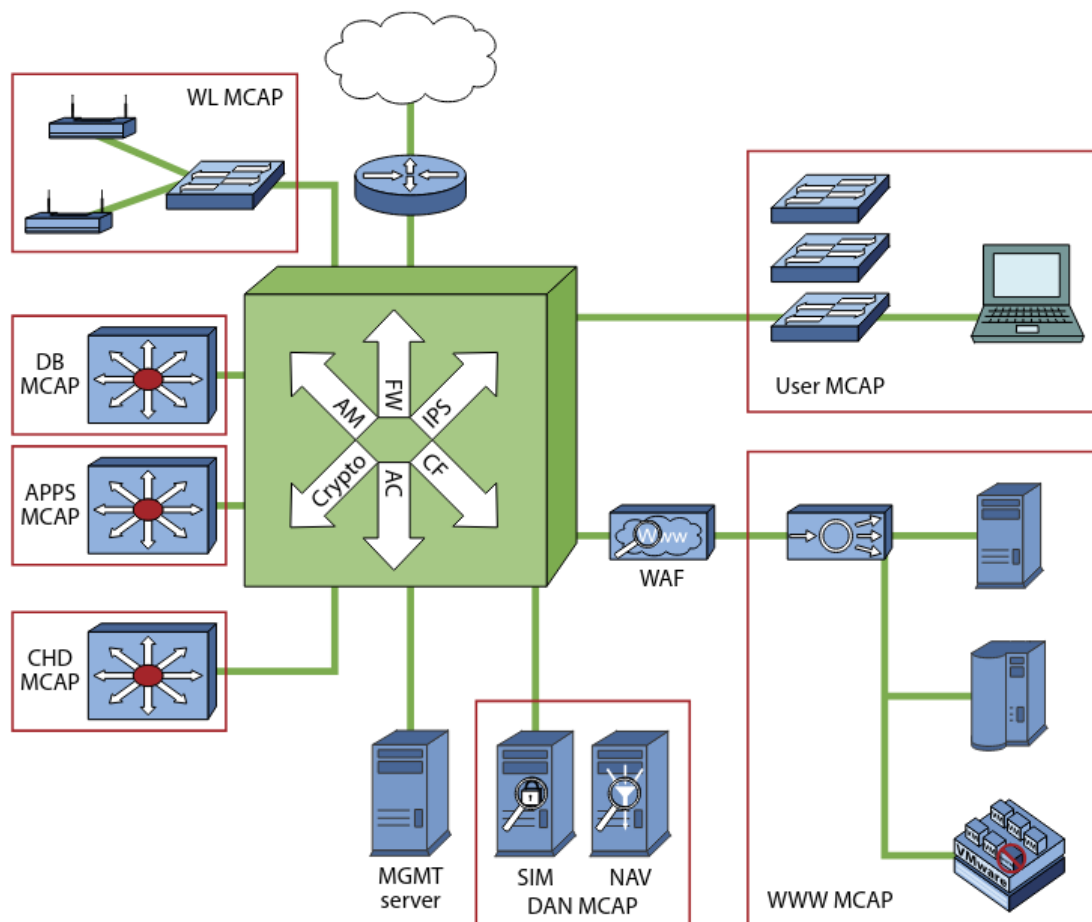
Kindervag's lösning på problemet bygger på en modulär och segmenterad säkerhetsmodell med en central knutpunkt där alla säkerhetsmekanismer existerar (2.5). Den centrala knutpunkten kallar Kindervag för: *Segmentation Gateway* (2.4). Kindervag går inte in på en teknisk nivå på hur SG skulle fungera, så denna lösning får tolkas på egen hand. Uppgiften som SG i själva verket gör är *styra, kontrollera och filtrera* nätverkstrafik.



Figur 2.4: Segmentation Gateway[2]

I Kindervag's säkerhetsmodell placerar SG som den centrala knutpunkten mellan flera *Microcore and Perimeter* (MCAP) zoner. Dessa zoner gör det enkelt att segmentera nät på ett säkert sätt. Traditionella *Virtual LAN* kan i vissa fall, beroende på konfiguration och planering, visas ineffektiva som säkerhetsmekanism då det kan, med enkla verktyg, avlyssnas och manipuleras av angripare. Tydliga fysiska zoner, som Kindervag påpekar med zoner, löser detta problemet. Dessa zoner grupperas efter liknande funktionalitet och globala policyattribut.

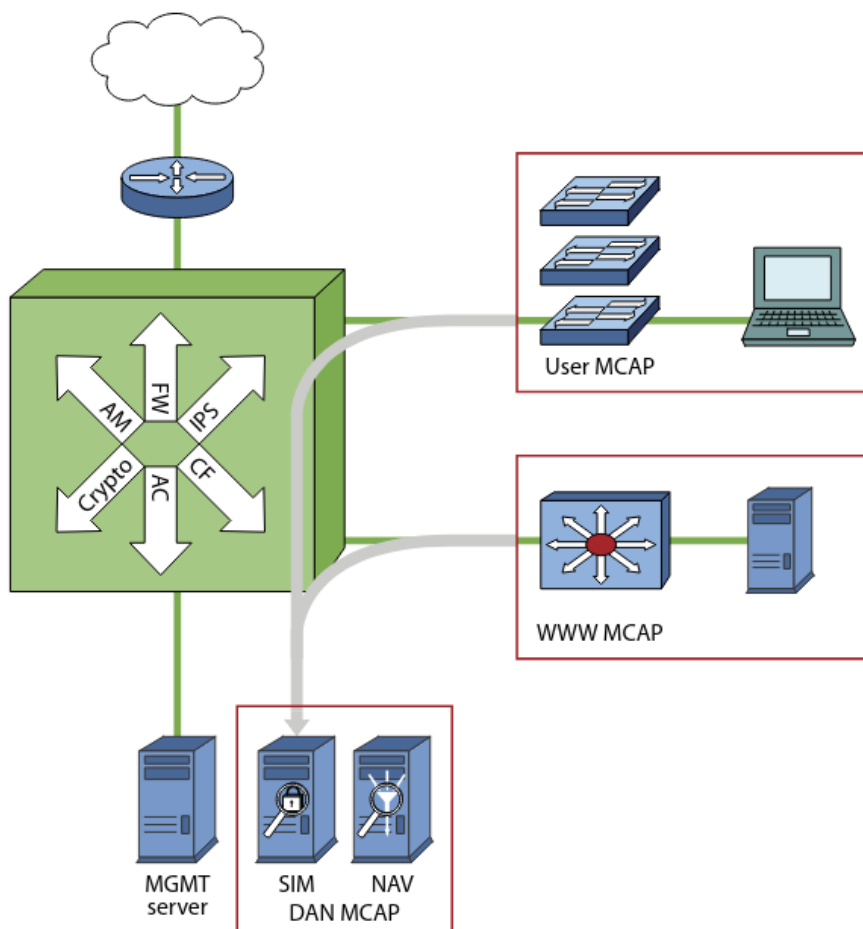
Kindervag påpekar också att man kan applicera separata säkerhetsmekanismer mellan SG och MCAP. I nedanstående exempel så placeras en *Web applikationsbrandvägg* mellan SG och *WWW MCAP*.



Figur 2.5: Exempel på hur Kindervag's säkerhetsmodell kan implementeras [2]

Som påpekat tidigare är SG uppdrag att *styra, kontrollera och filtrera* nätverkstrafik, detta betyder att all nätverkstrafik flödar igenom SG:n. I figur 2.6 demonterar Kindervag en *data acquisition network (DAN)* MCAP. Nätverkstrafik speglas och kopieras från alla andra zoner (genom SG) till DAN, för att analysera trafiken med hjälp av *security information management (SIM)* och *network analysis and visibility (NAV)* verktyg.

DAN MCAP är ett exempel på hur andra typer av säkerhetsmekanismer skulle behövas att implementera där SG inte räcker till, detta skulle betyda att man behöver separata zoner för bl.a *access control*.



Figur 2.6: Kindervag's säkerhetsmodell med DAN MCAP

Med ytterligare zoner som tillhandahåller säkerhetsmekanismer för SG så blir det enkelt att få till en modulär struktur. Detta blir fördelaktigt att implementera, både från ett säkerhetsperspektiv men även från en nätverksadministrativ vy. Om man ska separera så mycket som möjligt minskar det komplexiteten i de separata systemen, vilken kan minska attackytan från angripare. Om en angripare får tillgång till en zon så blir det svårt att ta sig vidare till en annan zon.

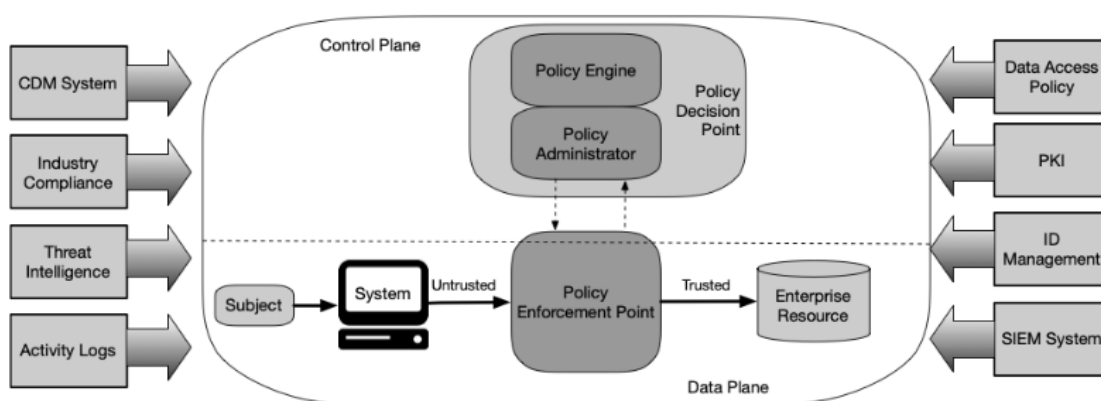
Kindervag's säkerhetsmodell ger en bra grund till vidare arbeten, men det finns en del

problem med modellen. Då Kindervag's artikel saknar tekniskspecifika lösningar finns det en del antaganden och tolkningar man måste göra på egen hand.

2.3.2 NIST 800-207: Zero Trust Architecture

NIST Special Publication 800-207, är en publikation av National Institute of Standards and Technology (NIST) där syftet bakom artikeln är att definiera en standard kring Zero Trust och skapa en tydlig grund till en Zero Trust Arkitektur (ZTA). NIST definierar Zero Trust och Zero Trust Arkitektur som följande:

Zero trust (ZT) provides a collection of concepts and ideas designed to minimize uncertainty in enforcing accurate, least privilege per-request access decisions in information systems and services in the face of a network viewed as compromised. Zero trust architecture (ZTA) is an enterprises cybersecurity plan that utilizes zero trust concepts and encompasses component relationships, workflow planning, and access policies. Therefore, a zero trust enterprise is the network infrastructure (physical and virtual) and operational policies that are in place for an enterprise as a product of a zero trust architecture plan.[3]



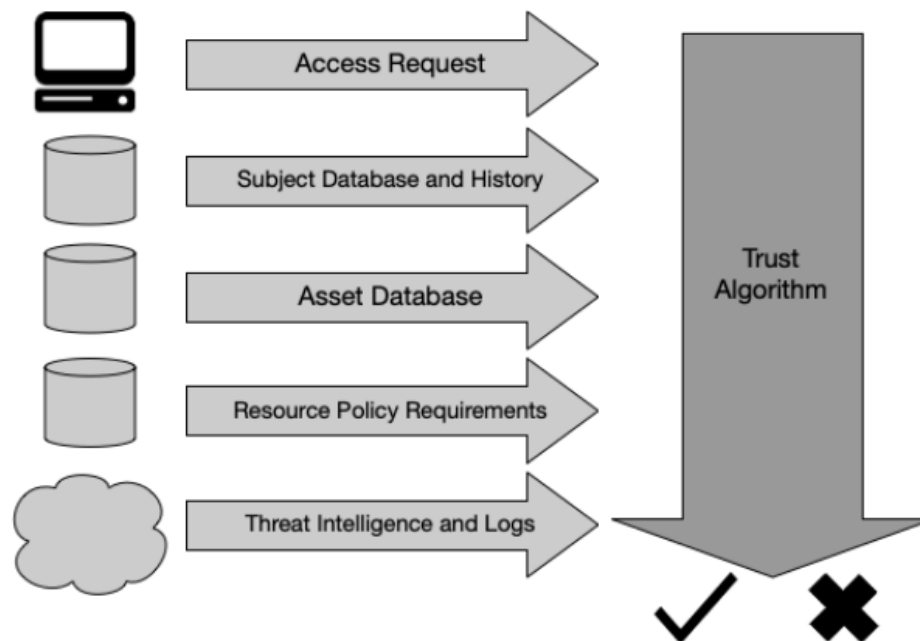
Figur 2.7: Logiska Kärnkomponenter i Zero Trust, från NIST [3]

NIST definierar flertalet olika logiska komponenter som borde implementeras i ZTA miljöer. Figur 2.7 beskriver relationen dessa olika komponenter har till varandra.

Kärnmoduler	
Policy engine (PE)	PE är den komponenten som gör det absoluta beslutet om att ge access till resurser. Detta görs via förutbestämda policies men även externa datakällor. Varje beslut som PE fattar beror på tidigare, nuvarande och möjliga framtida händelser. Se figur 2.8
Policy administrator (PA)	PA är den komponent som utövar besluten från PE till olika PEP. PE och PA ingår oftast i samma system, oftast beskrivs de då som Policy Decision Point (PDP).
Policy enforcement point (PEP)	Detta är olika komponenter i system och nätverk som fungerar som kommunikationskanaler mellan enheter och resurser. En användare kan inte komma åt en resurs utan att komma i kontakt med en PEP.
Datakällor	
Continuous diagnostics and mitigation (CDM) system	Samlar information kring enheters nuvarande tillstånd, e.g Operativsystem version och konfigurationer.
Industry compliance system	Policy kopplade till reglerande organ, detta skulle kunna vara regelverk som RÖS och Signalskydd.
Threat intelligence feed(s)	Datakälla om nya attacker och sårbarheter i system.
Network and system activity logs (NSAL)	Loggar från olika system, exempelvis nätverkstrafik, resurs access loggar, eller annan real-tids loggar.

Data access policies	Innehåller attribut, regler och policy om access till resurser. Fungerar som startpunkt för PE då detta fungerar som en grund till vilka användare och enheter har tillgång till vilka resurser.
Public key infrastructure (PKI)	Används för att generera, logga och hantera certifikat för olika system.
ID management system (IDMS)	Service för att skapa, spara och hantera användarkonton. Tillhandahåller också information som roller, access attributet och designerade resurser.
Security information and event management (SIEM) system	Hämtar säkerhetsrelaterad information för senare analys. Kan användas för att varna inför möjliga attacker.

Tabell 2.1: Komponenterna i NIST ZTA



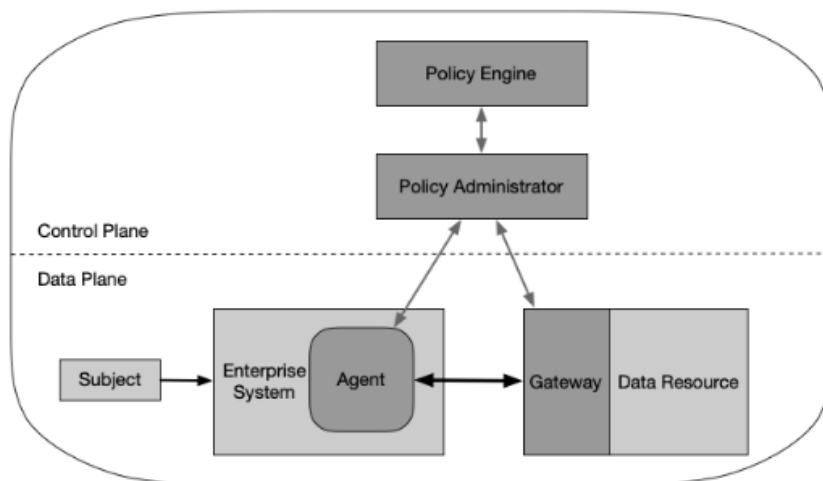
Figur 2.8: Trust Algorithm Input

I NIST-modellen så är kärnmodulernas jobb är att hantera access till resurser, baserad på informationen som tillförs via datakällorna. Varje PEP kommunicerar med PA varje gång någon försöker komma åt någon resurs, detta skulle kunna vara att komma åt det lokala nätverket eller en filserver. I figur 2.7 kan vi också se två stycken lager, *Control Plane* och *Data Plane*. I Control Plane så kommunicerar de olika beslutsfattande komponenterna (PDP och PEP) medan i Data Plane så kommunicerar alla andra enheter (subjekt till PEP till resurs). PEP fungerar som en gateway mellan subjekt/enheter och resurser.

Likt Kindervag's Zero Trust Modell så diskuterar NIST möjliga implementeringar av PDP och PEP i mikrosegmenterade *zoner*. Dessa zoner, också likt Kindervag's modell, bygger på att placera specifika individer, grupper eller resurser bakom någon form av gateway som fungerar som en PEP. Detta ger möjligheten att avgränsa hela zoner

bakom samma skyddande enhet. Detta tillvägagångssätt, till skillnad från nedanstående modeller, ligger på nätverksnivå.

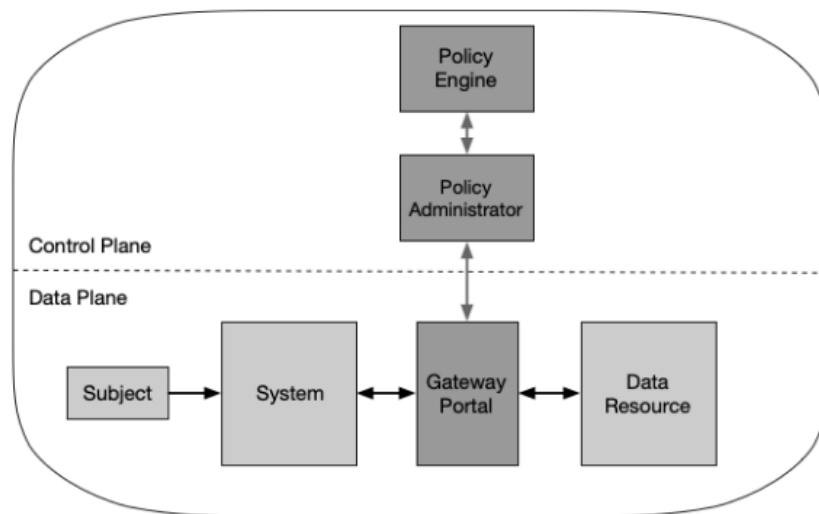
2.3.2.1 Device Agent/Gateway Model



Figur 2.9: Device Agent/Gateway Model[3]

Device Agent/Gateway Model bygger på att varje subjekts dator (eller liknande elektronisk enhet) är utrustad med en *device agent*. Denna agent kommer vidarebefordra access efterfrågningar direkt till PDP för evaluering. Om förfrågan godkännts så tillhandhåller PDP uppgifter till agenten och resursens gateway för att kunna starta en säker kommunikationskanal. Notera att resursens gateway är placerad direkt framför resursen som den enbart kommunicerar med, likt en proxy

2.3.2.2 Resource Portal Model



Figur 2.10: Resource Portal Model[3]

Resource Portal Model bygger på att kommunikationen mellan ett subjekts system och en resurs sker via en portal, där portalen fungerar som en PEP. Till skillnad från Device Agent modellen så behövs ingen agent på subjektets system för att kunna komma åt resurser. En nackdel med denna modell är att det inte finns någon integrerad service hos subjektets elektroniska enhet för att övervaka efter avvikelser i systemet, exempelvis fel i konfigurationer eller säkerhetsbrister.

Kapitel 3

Analys

3.1 Tolkning av KSF

Fastställning av konsekvensnivå och exponeringsnivå förekommer oftast från beställaren vid beställning av IT-system. Vissa antaganden måste göras då denna uppsats inte bygger på någon beställning. Antaganden bygger enbart på fiktiva scenarion.

Hur man väljer att klassa ett system utifrån KSF bygger på personliga tolkningar av användningsområden, vilket kan innebära att två olika personer kan komma till två olika klassningar. Därför kommer denna uppsats utgå ifrån att systemet skall möta en kravnivå på *Hög* utifrån kravnivån definierad i KSF (A.3).

Då vi inte kan definiera ett konkret scenario som denna lösning kommer användas i, så är det näst bästa alternativet att göra denna lösning applicerbar i så många fall som möjligt. Den systemdesign som kommer förekommer i denna uppsats bygger då på en universell lösning, detta menas att lösningen kommer kunna vara applicerbar i bland annat i kontroll-, utbildning- och träningscenter placerade i bland annat krigsområden. Tanken bakom detta är att uppsatsen kommer kunna ligga till grund till framtida arbeten

oberoende på situation.

Då denna lösning kommer fokusera på att vara universell så kommer det förekomma en del modulära lösningar (diskuteras mer senare), då är det viktigt att påpeka att denna typ av lösning då skulle klassas som *system-av-system*. KSF klassar *system-av-system* individuellt, detta betyder att en modulärt system, som beskrivs i Kindervags design, skulle varje separat segment/zon klassas som ett eget system, vilket i sin tur behöver en individuell klassning utifrån KSF.

3.2 Funktionella säkerhetskrav

Denna uppsats fokus ligger i att konstruera en system- och nätverksdesign, så de krav och kravkomponenter som berör just denna typ av design kommer diskuteras och tolkas. Detta menas med att krav och kravkomponenter som berör designen av hur olika system ska kommunicera med varandra kommer tolkas. Det förekommer också krav och kravkomponenter som kan tolkas som applikationsdesign, dessa kommer inte diskuteras då de inte är relevanta för detta arbete, dessa typer av krav skulle kunna innefatta mer specifika krav på hur en applikation ska bete sig individuellt, inte i sin helhet i relation till andra system.

3.2.1 Gemensamma krav; SFGK_FEL

SFGK_FEL definierar att ett säkert tillstånd måste upprätthållas vid fel i säkerhetsfunktioners konfiguration och funktionalitet. Detta inkluderar:

1. Ett definierat *säkert tillstånd* ska upprätthållas för de delar av systemet när säkerhetsfunktioners funktionalitet och/eller konfiguration (eller styrande data) är korrupt eller oåtkomlig.

2. Ingen användaraktivitet i systemet ska kunna ske om säkerhetsfunktioner är avstängda eller ur funktion.

Detta innebär att, om vissa säkerhetsfunktioner är ur funktion, ska inga typ av användaraktivitet kunna utföras i systemet. På en nätverksnivå så betyder detta att ingen kommunikation kommer kunna upprättas. Säkerhetsmekanismer skulle kunna inkludera, utifrån NIST modellen, PDP och PEP, men även andra typer av säkerhetsmekanismer som identitethanteringssystem (LDAP service).

3.2.2 Behörighetskontroll; SFBK_AUT, SFBK_ÅTK

Många av de kravkomponenter som finns för SFBK_AUT och SFBK_ÅTK bygger på de krav som ställs på just autentisering och åtkomstkontroll. Många kravkomponenter går att uppnå ifall man följer öppna standarder för autentisering samt åtkomstkontroll, dessa omfattas också av *Always Verify* och *Least Privilege* inom Zero Trust.

För att uppnå kraven för SFBK_AUT så måste följande kravkomponenter implementeras:

1. Varje subjekt måste autentisera sig vid inloggning och upprättande av session.
2. Subjekt ska autentiseras innan de ges åtkomst till objekt i systemet.
3. Säkerhetsattribut ska ha skydd mot obehörig avläsning och modifikation när dessa lagras eller transporteras i systemet.
4. Vid läsning eller revokering av säkerhetsattribut ska pågående sessioner för berört subjekt avslutas.

Dessa punkter uppnås per automatik ifall man uppnår *Always Verify* via exempelvis mTLS. Punkt 4 kan uppnås vid implementation av NIST Policy Detection Point (PDP),

PDP har möjligheten av avbryta pågående sessioner vid PEP om något skulle påvisa att sessionen inte är legitim.

För att uppnå SFBK_ÅTK så måste följande kravkomponenter implementeras:

1. Subjekt ska genom autentisering fastställda identitet ska alltid användas vid åtkomstkontroll till objekt.
2. Endast subjekt med tilldelad åtkomsträttighet ska ges åtkomst till objekt.

Dessa två punkter uppnås via *Least Privilege*, autentisering ska vara kopplat till en specifik unik person, vilket i sig är kopplat till vilka resurser subjektet har tillgång till. Subjektet ska också enbart ha tillgång till de resurserna som krävs för att kunna utföra sitt arbete.

3.2.3 Intrångsdetektering; SFID_DAT, SFID_ANA

SFID_DAT ställer krav på vilka typer av loggar som ska göras tillgänglig för analys och hur det ska hanteras. Något som är viktigt att påpeka här är att både system/applikationsloggar från själva systemet inkluderas men även nätverksloggar, alltså metadata från paket som färdas genom systemet då kärnan kommer fungera som en router. En annan viktig punkt som SFID_DAT påpekar är att alla loggar som ska göras tillgänglig för analys ska överföras till en systemgemensam analys- och detekteringsfunktion. Detta kan tolkas annorlunda, men SFID_ANA.14 specificerar att det ska hanteras av en avgränsat del av systemet, KSF specificerar detta som ett eget system.

SFID_ANA diskuterar hur analys av säkerhetsloggar och loggar ska ske, detta blir en avgränsning utifrån Kindstedt uppsats gällande AI verktyg av analys av loggar.

3.2.4 Intrångsskydd; SFIS_INT, SFIS_KIN, SFIS_KUT

SFIS_INT definierar de krav som borde ställas på systemet vid kommunikation mellan andra system. De krav som kravkomponenter ställer är att motparten måste autentisera sig innan överföring av data ska ske och att informationen som överförs måste skyddas från obehörig åtkomst och manipulation. mTLS är den främsta tekniken som används för detta syfte, för det kan både identifiera/autentisera unika användare men även krypterar trafiken mellan de två parter som pratar med varandra. I de fall där mTLS inte går att använda så bör andra säkra protokoll och metoder användas, exempelvis så borde SFTP användas istället för FTP.

3.2.5 Säkerhetsloggning; SFSL_REG, SFSL_SKY, SFSL_ANA

Vilka säkerhetsrelaterade händelser som ska loggas av systemet definieras av SFSL_REG. Vid varje loggad händelse ska också varje subjekts unika identitet visas. Enligt SFSL_REG så ska följande säkerhetshändelser loggas:

- All autentisering och försök till autentisering
- Skapande av nya identiteter och roller
- Förändringar av subjekts säkerhetsattribut som används för autentisering (ex. nytt certifikat eller bytt lösenord)
- Nekande av åtkomst till objekt, förutom då händelsen uppenbart inte har betydelse för säkerheten i systemet
- Alla förändringar av subjekts åtkomsträttigheter till objekt och funktioner
- Alla förändringar av objekts säkerhetsattribut som styr åtkomst
- Skapande av nya skyddsvärda objekt, t.ex. registerposter och handlingar

- Alla sekretessklassificeringsbeslut, t.ex. vid upprättande av handling
- All åtkomst till skyddsvärda objekt
- All förändring eller radering av skyddsvärda objekt
- Alla sökningar i register, diaries och liknande
- All export av information från systemet, inklusive utskrifter på papper
- Angiven identitet vid autentisering
- Varje upprättande av session
- Varje avslutande av session
- Konfigurationsförändringar i systemet
- Övriga händelser som har en betydande säkerhet i systemet

Dessa säkerhetshändelser är nödvändiga för att kunna analysera eventuella säkerhetsbrister eller kommande/pågående angrepp. Dessa säkerhetshändelser är också avgörande att ha vid behörighetsanalys hos *Policy Engine* i NIST modellen.

SFSL_SKY definierar att säkerhetsloggar inte får skrivas över eller raderas, alltså borde det egna systemet som hanterar säkerhetsloggar (som definieras tidigare under SFID_DAT) inte radera och manipulera säkerhetsloggar när de väl har skrivits till disk. Detta är viktigt så att inte angripare kan manipulera eventuella säkerhetsloggar för att hindra detektion.

SFSL_ANA beskriver att det måste finnas något form av system som kan analysera händelser i säkerhetsloggar. Systemet ska kunna detektera avvikelser i både kända (baserad på tidigare attacker) och okända (baserad på avvikelser i det normala beteendet hos system) attackmönster.

3.3 Analys av Kindervag's Zero Trust modell

Kindervag's Zero Trust modell lägger till stor del grunden till nätverk- och systemdesignen som kommer presenteras i denna uppsats. Därför är det då viktigt att analysera denna modell efter problem och svagheter, för att eventuellt hitta bättre lösningar eller alternativ.

3.3.1 Komplexitet

Komplexiteten i säkerhetsprinciper och program har gjort det betydligt svårt för privatpersoner, företag och organisationer att applicera moderna säkerhetsprinciper. Trender visar att företag väljer användarvänlighet framför säkerhet, men det är inte så det borde funka. Det finns fundamentala fel i dagens system som gör att säkerhet anses enbart som ett tillägg som enbart skapar problem och sällan något positivt.

Vid design av denna typ av lösning så borde det framgå tydligt hur säkerhetsmekanismer implementeras, det borde heller inte vara svårt att applicera ytterligare moduler till kärnsystemet utan krångliga konfigurationer. Det borde helst ske någon form av *handskakning* som kommer överens över de flesta konfigurationer. Oftast är dessa lösningar dyra då man överför ansvaret från användare till mjukvaran, vilket betyder att konfigurationer måste ske automatiskt. Ett exempel på system som förenklar konfiguration är Ubiquiti *Unifi* ekosystem.

Att implementera Zero Trust lösningar kan tilldela en viss komplexitet, detta i form av tekniska lösningar eller från en användares perspektiv. Kindervag's modell minskar komplexiteten i vissa aspekter, men samtidigt ökar den. Modellen minskar komplexitet med implementation av säkerheten i DNA:t av nätverket, men ökar komplexitet där

traditionella nätverk är bättre. Skalbarheten är ett problem som skapar komplexitet i Kindervag's modell (diskuteras mer ingående senare), men om man vill ha en skalbar lösning så uppstår det ytterligare komplexitet i hur säkerhetsmekanismer ska implementeras, speciellt i hur nätverksstrukturen borde vara.

3.3.2 Skalbarhet

Då Kindervag kritiserar mjukvarubaserad segmentering (VLAN) så måste antagandet ske att varje zon får sin egen fysiska anslutning till SG. Man kanske vill segmentera flera avdelningar på ett företag, vilket leder till många fysiska anslutningar till SG. Problemet med detta är att kunna skala upp denna typ av design på en större nivå. Då varje separat zon är gjord för att enbart segmentera liknande trafik så är det lätt att antalet zoner snabbt ökar, samtidigt som det enbart finns begränsat antal fysiska anslutningar till SG. För att kunna göra detta till en faktiskt lösning så behöver man göra designen både applicerbar och skalbart.

Ett problem som jag ser i Kindervags *segmentation gateway* är att kärnmodulen inte är skalbar på ett enkelt sätt, varje fysisk nätverksinterface leder till var sin egen segmenterad zon. Detta betyder att ett finns ett begränsat antal zoner som kan vara kopplade till SG. Fördelen med dagens nätverk är att det just är skalbart, man kan placera ut en enkel nätverksswitch när det finns behov av att utöka nätverket. Man skulle kunna applicera olika typer av Virtuella LAN (VLAN) för att kunna föra trafik för flera zoner över samma fysiska anslutning. Problemet med denna lösning är att man skulle kunna utföra *VLAN hopping*, vilket innebär att angripare kan låtsas vara i ett annat VLAN och avlyssna säkerhetskänslig information.

3.3.3 Tredje Part Implementeringar

Då det skulle vara kostsamt att utveckla ett helt nytt system för denna typ av lösning, så kan det vara attraktivt att implementera redan färdiga produkter i ekosystemet. Detta förenklas med en modulär struktur då man kan anpassa specifik kommunikation mellan SG till zoner för speciella ändamål, och då får enbart standardiserade protokoll användas för att kommunicera mellan zonen och övriga nätverket. Säg att man vill implementera en RBAC lösning för att hantera användare i miljön, så kan man skapa en ny zon med redan existerande mjukvara.

3.4 Analys av NIST Publikation 800-207

3.4.1 Control Plane och Data Plane

I NIST publikationen beskrivs det som en *Logisk separation* av två plan. Detta menas att både Control Plane och Data Plane kommunicerar i samma fysiska nätverk, men är oberoende och påverkar inte varandra. Alltså är kommunikationen utförd på ett sätt som gör att en angripare som avlyssnar nätverkstrafik, inte kan använda eller manipulera data som den kan se.

3.4.2 Device Agent/Gateway Model

Device Agent/Gateway Model erbjuder mer än bara access kontroll. I denna modell har agenten tre huvudsyften:

1. Tillföra access förfrågningar till PDP.
2. Gateway för subjekt att kunna ansluta sig till resurser på ett säkert sätt.
3. Tillföra enhetsinformation till PE för framtida evalueringar.

Problematiken i denna modell är dock att agenten behöver placeras på alla elektroniska enheter som behöver tillgång till någon form av resurs. Detta inkluderar inte bara laptops och stationära datorer, men även andra typer av elektroniska enheter. Detta kan vara *mikrokontrollers*, *legacy system* och andra *okonventionella system*. Då olika enheter kan vara byggda för olika ändamål, så kan kompatibiliteten av agenten variera mellan olika system. Man vill inte glömma att syftet bakom agenten är att också samla in data om just systemet, och det kan ske på olika sätt beroende på system. Exempelvis kan det behövas olika kodbasen för att kunna köra en sådan agent på både Window och Linux, men även ifall man även vill köra dessa på ESP32 eller STM32 mikrokontrollers.

3.4.3 Resource Portal Model

Resource Portal Model löser problemet med okonventionella och legacy system. Denna lösning bygger på, mer eller mindre, en proxy lösning när man autentiserar och kommunicerar med en mellanpunkt. I figuren 2.10 så fungerar *Gateway Portal* som en proxy. Problemet blir då att man går miste om systeminformation som kan upptäcka eventuella sårbarheter i systemet hos subjekt, enda gången enheterna kan ge systeminformation är vid anslutning till en resurs.

3.4.4 Angrepp mot PDP

I NIST modell så är PDP modulen den viktigaste komponenten, vilket resulterar i att majoriteter av attacker kommer ske mot just PDP modulen. Målet med dessa angrepp behöver nödvändigtvis inte vara att få direkt tillgång och styra besluten från PE, men kan vara att störa eller överbelasta PDP modulen. *Denial-of-Service (DOS)* attacker är rätt enkla för angripare att utföra, men kan orsaka stora konsekvenser inom nätverket, man får inte glömma att tillgången till alla resurser bygger på att PDP komponenten går att nå.

Många av angreppen går att förhindra till följd av Zero Trust, om vi märker av att en oväntad stor mängd nätverkstrafik kommer från en plats i nätverket går det att blockera trafik från den zonen. Detta skulle förhindra DOS-attacker i stora drag. Om man följer Resource Portal Model så kan man tydligt bestämma vart trafiken till PDP kommer ifrån, om man enbart tillåter trafik från PEP system till PDP så kan man ignorera all annan trafik, detta blir ju en konsekvens av *Control- och Data Plane*.

Kapitel 4

Design

4.1 Designprinciper

Dessa designprinciper fungerar som förhållningsregler för hur system- och nätverksdesignen ska konstrueras. Dessa representerar inga fysiska komponenter i designen, som exempelvis SG, PDP eller PEP komponenter, utan existerar på en logisk nivå, på hur system ska byggas eller kommunicera.

4.1.1 Isolerad miljö

Ett av målen med denna uppsats är att ta fram en lösning som är applicerbar i en isolerad miljö. Detta innebär att designen inte kommer vara uppkopplat mot något externt nätverk, och som konsekvens av detta behöver alla säkerhetsmekanismer vara placerade i det interna nätverket.

Det finns, i viss utsträckning, lösningar där man avlastar beräkningstunga uppgifter på *cloud*-baserade lösningar. Detta skulle kunna vara analys av nätverkstrafik eller liknande uppgifter. Detta görs dels för att spara på kostnader för egen hårdvara, men även att man

kan göra lösningar skalbara när extra beräkningskraft behövs, man kan helt enkelt enbart betala för den beräkningskraft man behöver.

Att tillhandahålla egen hårdvara kan bli dyrt, men i detta fall är det nödvändigt samtidigt som det kommer med vissa fördelar.

- **Bättre svarstider:** Att placera allt nära till hands kan ge bättre svarstid då routing och tillgänglighet bygger på eget ansvar.
- **Bättre säkerhet:** Man vet inte hur cloud företag tillhandahåller sina maskiner, och vilken access andra delar av företaget har. I stora drag så vet vi inte hur de tilldelade maskinerna används till, utöver det man kan se som kund.
- **Bättre tillgänglighet:** Tillgänglighet är viktigt för att inte avbryta eventuellt arbete som utförs på nätverket, om man tillhandahåller egen hårdvara kan man själv bestämma när system behöver gå ner för underhåll och inte förhålla sig till andra företag.

4.1.2 Segmentering

Segmentering är ett kraftfullt verktyg inom Zero Trust, för det ger möjligheten till att dela upp nätverk och system så att de enbart kan kommunicera med varandra på ett selektivt och begränsat sätt, vilket i sig minskar attackytan och antalet möjliga attacker mellan olika system.

På nätverksnivå kan detta uppnås genom mikrosegmentering där varje zon enbart tillåts kommunicera med de zoner som är strikt nödvändiga för dess funktion, styrt av brandväggsregler i SG. Detta innebär att även om en angripare lyckas kompromettera en zon, så begränsas möjligheten till *lateral movement* kraftigt då trafik mellan zoner alltid

måste passera genom SG och dess säkerhetskontroller.

Segmenteringen kompletteras på systemnivå av NIST:s PEP-komponenter, som fungerar som grindvakter för varje resurs. Varje åtkomstförfrågan måste godkännas av PDP innan en session kan upprättas, vilket innebär att segmenteringen inte enbart sker på nätverksnivå utan även på applikations- och resursnivå. Tillsammans skapar nätverkssegmentering och PEP ett flerlayers skydd där en angripare måste forcera flera oberoende säkerhetsmekanismer för att nå känsliga resurser.

4.1.3 Modularitet

En modulär design ger möjligheten att enbart applicera de delar av systemet för att nå de krav som ställs på systemet. Denna lösning ger stora möjligheter till ytterligare säkerhet då man minskar komplexiteten i systemet, vilket minskar risken för eventuella säkerhetshål som uppstår till följd av komplexitet.

Ytterligare fördelar ligger i att lösningen till viss del är skalbar, man kan använda flera instanser av olika moduler ifall någon av dem skulle sluta fungera. Detta går också hand i hand med att delar av lösningen kan fortsätta användas som vanligt ifall någon resurs skulle bli otillgänglig.

Om man placerar varje individuell säkerhetsmodul bakom sin egen zon, baserad på Kindervags modell, så kan man minska varje individuell moduls attackyta, vilket gör det svårare för angripare att ta över hela system. Utöver att modularitet kan ge bättre tillgänglighet i systemet, så lägger det också grunden till segmenteringen av nätverksstrukturen, som Kindervag beskriver i sin säkerhetsmodell.

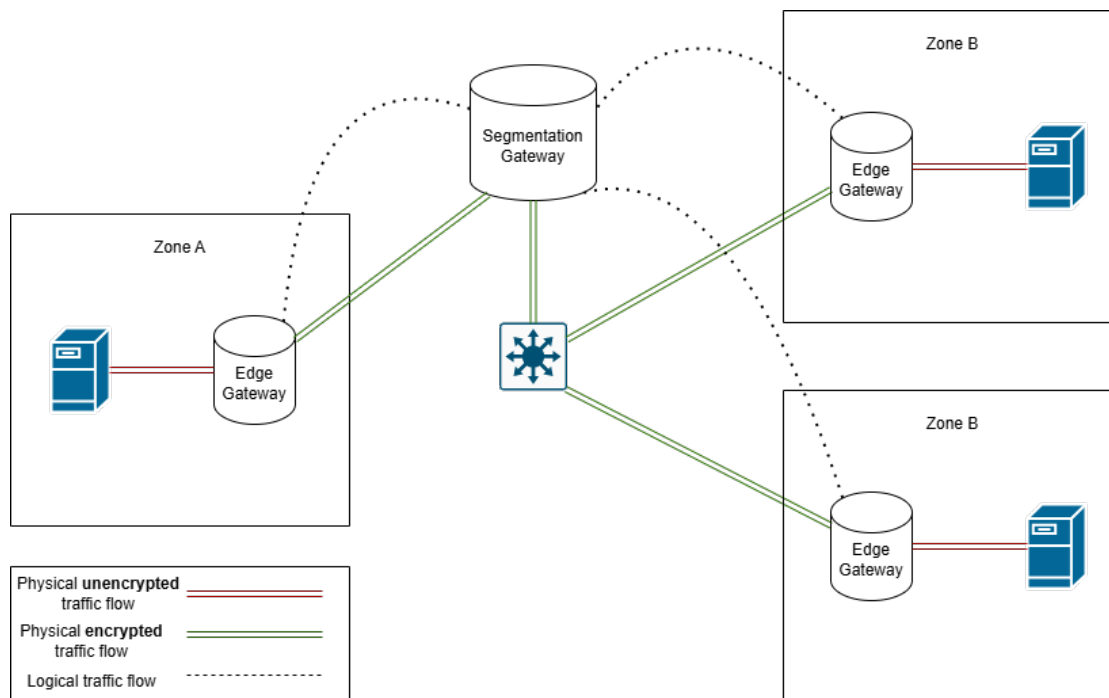
Utifrån NIST modellen, med PDP och PEP enheter, så kan man utesluta vissa datakällor

där det inte finns behov, detta utan att påverka funktionaliteten i PE. Detta är för att PE styr åtkomsten till resurser genom information den får av datakällor, så mängden datakällor kan variera beroende av behov. En större mängd data kan såklart resultera i mer logiska beslut, men säg att man implementerar denna modell i ett system där det inte finns behov av att analysera systemloggar, då kan PE fortfarande fatta beslut.

4.1.4 Skalbarhet

Att designen är skalbar är en oerhört viktig egenskap om modellen ska kunna vara tillämpbar i verkliga scenarion. En av svagheter i Kindervag's modell ligger i just att den är svårt att göra modellen skalbar utan att introducera ytterligare komplexitet. En möjlig lösning till problemet, är att applicera någon form av *Site-to-Site VPN* mellan varje zon och kärnmodulen. Detta löser även problemet med avlyssning då kommunikationen mellan olika zoner är krypterad som standard, vilket inte gör det möjligt att avlyssna innehållet i trafiken. Om man använder en *Site-to-Site VPN* lösning så kan man placera en *opålitlig* nätverksswitchar mellan SG och olika zoner utan att oroa sig för avlyssning eller manipulation.

Varje Edge Gateway har en direkt krypterad tunnel (VPN) till den centrala Segmentation Gateway. Detta gör att man kan placera *opålitliga* switchar eller andra nätverkskomponenter mellan EG och SG utan att riskera att angripare kommer åt känslig information, samtidigt bibehålla den interna strukturen på nätverket. Det man vill åstadkomma med denna lösning är just att få ett nätverksflöde genom SG för att kunna logga all trafik som sker mellan zoner, enbart legitima Edge Gateways kommer kunna ta emot trafik från SG.



Figur 4.1: Skalbar Site-to-Site lösning

För att en Edge Gateway ska anses legitim krävs det att den kan autentisera sig mot SG vid uppstart av VPN-tunneln, vilket kan realiseras via ömsesidig certifikatautentisering i linje med Always Verify-principen. Certifikaten utfärdas av en intern PKI-tjänst placerad i en dedikerad zon, vilket innebär att varje EG har ett unikt certifikat som kan återkallas centralt om en zon skulle komprometteras.

En ytterligare fördel med denna lösning är att antalet fysiska anslutningar till SG inte längre begränsar antalet zoner, vilket var ett av de fundamentala skalbarhetsproblemen i Kindervags ursprungliga modell. Istället kan flera EG dela samma fysiska länk mot SG via krypterade tunnlar, där SG ändå kan särskilja och filtrera trafik per zon baserat på tunnelidentitet.

4.1.5 Data/Control Plane

NIST beskriver Control och Data Plane som två logiska separata kommunikationsplan med samma fysiska nätverk. Separationen säkerställer att beslutsfattande komponenter (PDP och PEP) inte kan påverkas eller störas av trafik i det övriga nätverket.

Control Plane innefattar kommunikationen mellan PDP och dess PEP-noder. Denna trafik är strikt begränsad, enbart PEP-noder med giltiga certifikat utfärdade av den interna PKI-tjänsten får kommunicera med PDP. Detta innebär att en komprometterad zon i Data Plane inte kan påverka beslutsfattandet i Control Plane, förutsatt att certifikaten inte är komprometterade.

Data Plane innefattar all övrig kommunikation, subjekt till PEP, och PEP till resurs. Trafik i Data Plane kan aldrig nå PDP direkt, utan måste passera genom en PEP som i sin tur kommunicerar uppåt till Control Plane vid behov.

För att ytterligare skydda Control Plane placeras PDP i en egen dedikerad zon, vars enda tillåtna inkommande trafik är från autentiserade PEP-noder. Detta binder samman separationen av de två planen med segmenteringsprincipen som beskrivs i sektion 4.1.2, och adresserar samtidigt den sårbarhet mot angrepp mot PDP som identifierades i sektion 3.4.4.

4.2 Specifikationer och Krav

För att veta hur man ska strukturera kommande diagram så måste vi veta de krav och specifikationer som ska ställas på system- och nätverksdesignen. Vi har två utgångspunkter som vi måste uppfylla, främst är det att uppnå en design som grundar sig i Zero Trust principer, och den andra som uppfyller kraven från Försvarsmaktens KSF.

4.2.1 Zero Trust

Utifrån de tre grundprinciperna identifieras följande tekniska krav på designen:

Always Verify: All kommunikation mellan enheter, användare och resurser ska autentiseras kontinuerligt. Detta realiserar primärt via mTLS, som kräver att båda parter presenterar giltiga certifikat utfärdade av en intern PKI-tjänst. Samma logik presenteras för VPN tunnlar mellan SG och EG. Sessioner som inte kan verifiera sin identitet ska omedelbart avbrytas. PDP-komponenten (Policy Decision Point) ansvarar för att fatta och verkställa dessa beslut via PEP-noder placerade framför varje resurs.

Least Privilege: Varje subjekt, oavsett om det är en användare, applikation eller systemenhet, ska enbart ha tillgång till de resurser som krävs för att utföra sin specifika funktion. På applikations- och användarnivå uppnås detta via RBAC och/eller ABAC kopplat till ett centralt identitetshanteringssystem (ID management). På nätverksnivå realiserar principen genom mikrosegmentering där varje zon enbart tillåts kommunicera med de zoner som är strikt nödvändiga, styrt av brandväggsregler i Segmentation Gateway (SG).

Assume breach: Systemet ska kontinuerligt övervaka nätverkstrafik och användarbeteende för att detektera avvikelser. Alla säkerhetshändelser (se sektion 3.2.5) ska loggas till ett dedikerat, skrivskyddat loggningssystem som inte kan manipuleras av komprometterade zoner. Vid detekterad avvikelse ska berörd zon kunna isoleras automatiskt utan att påverka övriga delar av systemet, i linje med den modulära designprincipen.

4.2.2 KSF-krav mappade mot designval

För att se tolkningar på kraven, se sektion 3.2.

För att se beskrivning på krav utifrån KSF, se figur A.4.

Krav	Hur det adresseras i designen
Gemensamma krav (SFGK)	
SFGK_FEL	Om PDP, PEP eller annan säkerhetsfunktion är otillgänglig stängs all nätverkskommunikation. Ingen session kan upprättas utan fungerande säkerhetsfunktioner.
Behörighetskontroll (SFBK)	
SFBK_AUT	mTLS säkerställer ömsesidig autentisering vid varje sessions-uppbyggnad. PDP kan återkalla aktiva sessioner vid certifikatrevokering eller anomalidetektering.
SFBK_ÅTK	RBAC/ABAC kopplat till ID management-system. Subjektets autentiserade identitet används alltid som grund för åtkomstkontroll via PEP.
Intrångsdetektering (SFID)	
SFID_DAT	All nätverkstrafik passerar SG och genererar metadata/nätverksloggar. Loggar från alla zoner samlas i ett dedikerat loggningssystem (separat zon).
SFID_ANA	Dedikerat logganalysystem (koppling till Kindstedts arbete om AI/LLM för logganalys). Detekterar både kända och okända attackmönster utifrån SFSL_ANA.
Intrångsskydd (SFIS)	
SFIS_INT	mTLS krypterar och autentiserar all kommunikation mellan zoner. Site-to-Site VPN-tunnlar skyddar trafik mellan EG och SG.

Krav	Hur det adresseras i designen
SFIS_KIN	SG inspekterar all inkommande trafik mellan zoner. Enbart trafik från autentiserade EG med giltiga certifikat accepteras.
SFIS_KUT	SG filtrerar utgående trafik. Brandväggsregler begränsar vilka zoner som kan initiera kommunikation mot vilka resurser.
Säkerhetsloggning (SFSL)	
SFSL_REG	Alla händelser definierade i SFSL_REG (autentiseringsförsök, sessionsuppbyggnad, åtkomstförändringar m.m.) loggas via NSAL i dedikerad loggzon.
SFSL_SKY	Loggningszonen (NSAL) är en separat zon med enbart skrivrättigheter från övriga zoner, ingen zon kan modifiera eller radera befintliga loggar.
SFSL_ANA	SIEM-systemet i loggzonen analyserar händelser kontinuerligt. Integreras med PDP för att kunna begränsa åtkomst till resurser beroende på händelser vid system i realtid.

Tabell 4.1: Funktionella säkerhetskrav kopplade mot designval

4.3 System- och Nätverksarkitektur

System och nätverksarkitekturen bygger på en kombination av Kindervags säkerhetsmodell och NIST PDP/PEP-komponenter.

4.3.1 Komponenter

Komponent	Syfte
Segmentation Gateway (SG)	Central knutpunkt i nätverket. All trafik mellan zoner passerar genom SG, som filtrerar och kontrollerar kommunikationen via brandväggsregler. Fungerar som kärnan i Kindervags säkerhetsmodell. Kan även fungera som PEP då all trafik mellan zoner passerar genom SG.
Edge Gateway (EG)	Placeras vid varje zon och fungerar som en endpoint för att upprättar en krypterad Site-to-Site VPN-tunnel mot SG. Autentiserar sig mot SG via certifikat utfärdade av PKI-tjänsten, i linje med Always Verify-principen. Kan även fungera som PEP för trafik inom sin zon.
Resource Gateway (RG)	Placeras precis framför varje åtkomlig resurs. Agerar som en proxy mellan subjekt och resurs där den agerar endpoint för resurs. RG hanterar mTLS sessionen mot subjekt samt autentiserar och auktoriserar subjekt för resurs.
Policy Decision Point (PDP)	Består av Policy Engine (PE) och Policy Administrator (PA). Fattar beslut om åtkomst till resurser baserat på datakällor och förutbestämda policys. Kommunikerar med PEP-noder via Control Plane.

Komponent	Syfte
Policy Enforcement Point (PEP)	Placeras framför varje resurs och fungerar som en gateway mellan subjekt och resurser. Vidarebefordrar åtkomstförfrågningar till PDP och verkställer dess beslut. Ingen resurs kan nå utan att passera en PEP. I denna design kan SG och EG även fylla rollen som PEP, se respektive komponent.
Public Key Infrastructure (PKI)	Hanterar utfärdande, loggning och återkallande av certifikat för alla komponenter i systemet. Utgör grunden för mTLS-autentisering och VPN-tunnlar.
ID Management System (IDMS)	Hanterar användarkonton, roller och åtkomstattribut. Tillhandahåller information till PE som grund för åtkomstkontroll via RBAC/ABAC. Kan implementeras via exempelvis en LDAP-tjänst.
Security Information and Event Management (SIEM)	Analyserar säkerhetsrelaterade händelser lagrade i NSAL. Detekterar avvikelser och kända attackmönster. Integreras med PDP för att kunna påverka åtkomstbeslut i realtid. Uppfyller kraven från SFSL_ANA och SFID_ANA.
Network and System Activity Logs (NSAL)	Lagrar all nätverkspaket metadata och alla säkerhetshändelser definierade i SFSL_REG. Zonen är skrivskyddad från övriga zoner, vilket innebär att ingen komponent kan modifiera eller radera befintliga loggar. Uppfyller krav från SFSL_SKY.

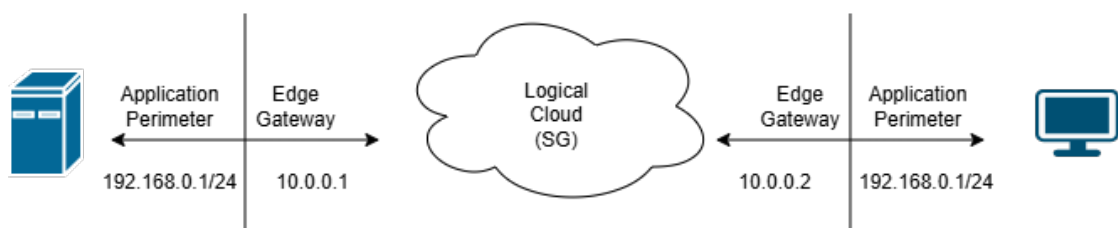
Tabell 4.2: Komponenter i System och Nätverksdesign

4.3.2 Zonstruktur

Varje separat zon ska behandlas som en isolerad miljö, och enbart relaterade system ska befinna sig i samma zon. Detta är för att lättare kunna isolera och segmentera trafik i de fall där angrepp kan komma från zoner. Om en zon blir isolerad/bortkopplad av någon anledning så kan resterande av nätverket fungera (så länge det inte är en säkerhetsmekanism, för då kan inte resterande av systemet fungera enligt SFGK_FEL).

Varje Edge Gateway, som är placerad framför varje zon som en endpoint, sätter upp en krypterad *end-to-end* tunnel till Segmentation Gateway. Varje Edge Gateway tilldelas en simpel brandvägg där den tillåter enbart trafik från Segmentation Gateway, detta för att filtrera ut oönskad trafik från andra i nätverket. Den har också en *Policy Enforcement Point* för att kunna evaluera åtkomst till det resterande nätverket från subjekt.

En zon består av två delar, Edge Gateway och *Application Perimeter*. Edge Gateway hanterar kommunikationen mellan zonen och Segmentation Gateway, medan Application Perimeter är den logiska nivån där subjekt, resurser och andra system finns. Ur ett nätverksperspektiv så fungerar varje Application Perimeter som sitt eget nätverk, där kopplingen till andra zoner agerar som externa nätverk, likt hur nuvarande nätverk ser på internet.



Figur 4.2: Logisk Struktur för Application Perimeter

4.3.3 Resource- eller Device Agent Gateway model?

Båda modellerna uppfyller olika syften och har sina fördelar och nackdelar. Man får ha i åtanke att system som används i denna design följer och stödjer industristandarder för TLS och kryptering. Det är viktigt i sådana system att inte bara mjukvara och nätverk fungerar som det ska, men även hårdvara. Därför kommer legacy och okonventionella system, som inte stödjer autentisering via mTLS, avrådas från att användas. Alternativt så skulle det kunna konstrueras hårdvarubaserade proxyenheter. Dessa kan funka som ett tillägg till system som inte stödjer de kryptering algoritmerna som ska användas. Detta fungerar likt resource gateway som visas på figur 2.10 fast för ett subjekt.

Denna design kommer då bygga på två lösningar, en för konventionella system (Windows och Linux system) och en för okonventionella system (legacy system).

- Konventionella system: Mjukvarubaserad agent som kan autentisera systemet mot EG och resurser genom mTLS, samlar också in systeminfo till PE.
- Okonventionella system: Hårdvarubaserad lösning, fungerar som ett fysiskt tillägg som hanterar autentisering mot EG och resurser. Kan dock inte samla in systeminfo till PE.

4.3.4 Kommunikationsflöden

För att ett subjekt ska kunna komma åt en resurs så behöver de gå igenom en rad olika Policy Enforcement Points. Ett subjekt kan komma åt en resurs först när tillhörande zons Edge Gateway autentiserar sig mot Segmentation Gateway, PDP bestämmer ifall de kan ansluta eller inte. Ett subjekt autentiserar sig mot zonens Edge Gateway för att sedan kunna komma en resurs i en annan zon. Subjekt behöver också autentisera sig mot resursens *Resource Gateway* för att se ifall subjektet har tillräckligt med privilegier för att kunna komma åt resursen.

Följande lista beskriver i ordning hur trafiken borde följas:

Initierande trafik: Trafik som ska sättas upp oberoende på om någon klient försöker kommunicera med en annan zon. Se figur 5.2 EG INIT Authentication.

0. **SG autentiserar sig mot PDP 4.3.4(edge case):** Utöver den vanliga Site-to-Site VPN anslutningen som sker mellan varje EG och SG så sätts en mTLS session upp mellan SG och PDP. Detta för att kunna autentisera sig och hålla trafiken krypterad. Detta är en förutsättning för att resterande kommunikation i nätverket ska kunna ske, i linje med SFGK_FEL. Om denna session inte kan upprättas ska ingen annan kommunikation tillåtas.
1. **EG ansluter sig till SG:** När en EG startar upp försöker den upprätta en VPN-tunnel mot SG.
2. **SG ställer en autentiserings/anslutnings förfrågan till PDP** som kontrollerar EG:ns certifikat mot PKI-tjänsten och verifierar att EG är behörig att ansluta sig till nätverket.
3. **En VPN session sätts upp mellan SG och EG:** Om PDP godkänner förfrågan tillåts tunneln att etableras, annars nekas anslutningen.
4. **Kontinuerlig verifiering:** PDP övervakar kontinuerligt alla aktiva sessioner, både mot SG och anslutna EG-noder. Om ett certifikat återkallas eller en enhet uppvisar avvikande beteende kan PDP avbryta sessionen omedelbart, i linje med Always Verify-principen. PDP hämtar data från informationskällor för att kunna besluta om att sessionen borde fortsätta vara igång.

EDGE CASE: När en PDP zon ska anslutas för första gången och det inte finns någon redan existerande PDP zon inkopplad finns det inget som kan autentisera PDP zonens EG. En lösning är att PDP:s zon behandlas som ett specialfall vid uppstart. **SG, PDP:s EG och PDP har förinstallerade certifikat**, det är viktigt att dessa tre

komponenter har varandras certifikat för att kunna lita på varandra vid uppstart, detta då det inte finns någon PKI som kan utfärda certifikat vid detta steget. Se figur 5.2 PDP EDGE CASE.

1. SG och PDP:s EG autentiserar sig genom att dela sina förinstallerade certifikat, detta gör det möjligt att sätta upp VPN tunneln för att senare kunna kommunicera med PDP.
2. EG och PDP autentiserar sig med sina förinstallerade certifikat för att säkerställa att det är rätt system som de kommunicerar med.
3. SG och PDP autentiserar sig med sina förinstallerade certifikat genom mTLS.

Styrande Data: Logiska Control Plane; Data mellan PEP och PDP.

1. **PEP vidarebefordrar åtkomstförfrågan:** När ett subjekt försöker nå en resurs tar närmaste PEP-enhet emot förfrågan och vidarebefordrar den uppåt i kedjan mot PDP. Beroende på var subjektet och resursen befinner sig kan flera PEP-enheter vara involverade, exempelvis RG -> EG -> SG -> PDP. Varje länk i kedjan är skyddad av mTLS för att säkerställa att förfrågan inte kan manipuleras under transport. Olika PEP-enheter kan också innefatta olika funktionalitet i kedjan, EG hanterar kommunikationen in och ut ur zonen och RG hanterar vilka som kan komma åt specifika resurser.
2. **PDP fattar och verkställer beslut:** PDP utvärderar förfrågan baserat på subjektets identitet, roll och tilldelade rättigheter från ID management-systemet, samt aktuell hotinformation från SIEM-systemet. Om förfrågan godkänns instruerar PDP berörda PEP-enheter att öppna upp kommunikationskanalen. Om förfrågan nekas stängs kanalen och händelsen loggas i loggningszonen.

Applikationsdata: Logiska Data Plane; Från ett subjekt i en zon till en resurs i en annan zon.

1. **Sessionen etableras:** När PDP har godkänt förfrågan och berörda PEP-enheter har fått instruktioner kan subjektet börja kommunicera med resursen. Trafiken flödar genom de etablerade VPN-tunnlarna via EG och SG, och passerar alltid genom minst en PEP-enhet innan den når resursen.
2. **Trafiken inspekteras:** All trafik som passerar genom SG inspekteras och metadata loggas till loggningszonen. SG tillämpar brandväggsregler för att säkerställa att enbart godkänd trafik flödar mellan zoner, i linje med SFIS_KIN och SFIS_KUT.
3. **Sessionen avslutas eller förnyas:** När subjektet avslutar sin session, eller om PDP detekterar en avvikelse under sessionens gång, avslutas alla aktiva kanaler omedelbart. Om sessionen behöver förnyas måste en ny autentisering ske mot PDP, vilket säkerställer att åtkomsträttigheter alltid är aktuella.

4.3.5 Control/Data Plane i nätverket

Det som gör Control Plane speciellt ur säkerhetssynpunkt är att om en angripare kan påverka Control Plane så kan de styra hela systemets säkerhetsbeslut. De behöver inte bryta sig in i en resurs direkt, de kan istället manipulera PDP till att fatta felaktiga beslut, vilket ger dem tillgång till allt.

Därför ska följande punkter implementeras för att skydda Control Plane:

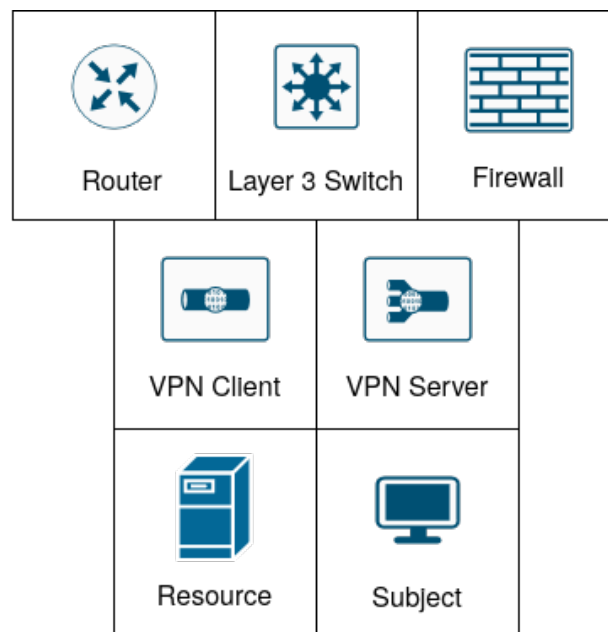
1. **Enbart autentiserade PEP-noder får kommunicera med PDP:** Det blir en mindre attackyta ifall enbart selekterade system får kommunicera direkt med PDP.
2. **PDP placeras i en egen isolerad zon:** Strikta brandväggsregler och policys hos PA bestämmer vilken nätverkstrafik som kan släppas igenom, detta borde också styras dynamiskt för att blockera eventuella misstänksamma PEP-noder.

3. **All control plane-trafik autentiseras och krypteras separat:** Andra system och PEP noder borde heller inte kunna manipulera eller se PEP noders förfrågningar, detta är att hindra eventuella misstänksamma system att störa Control Plane.

Kapitel 5

Resultat

Detta kapitel kommer presentera system- och nätverksdesign utifrån den design som diskuterades i föregående kapitel 4 Design.



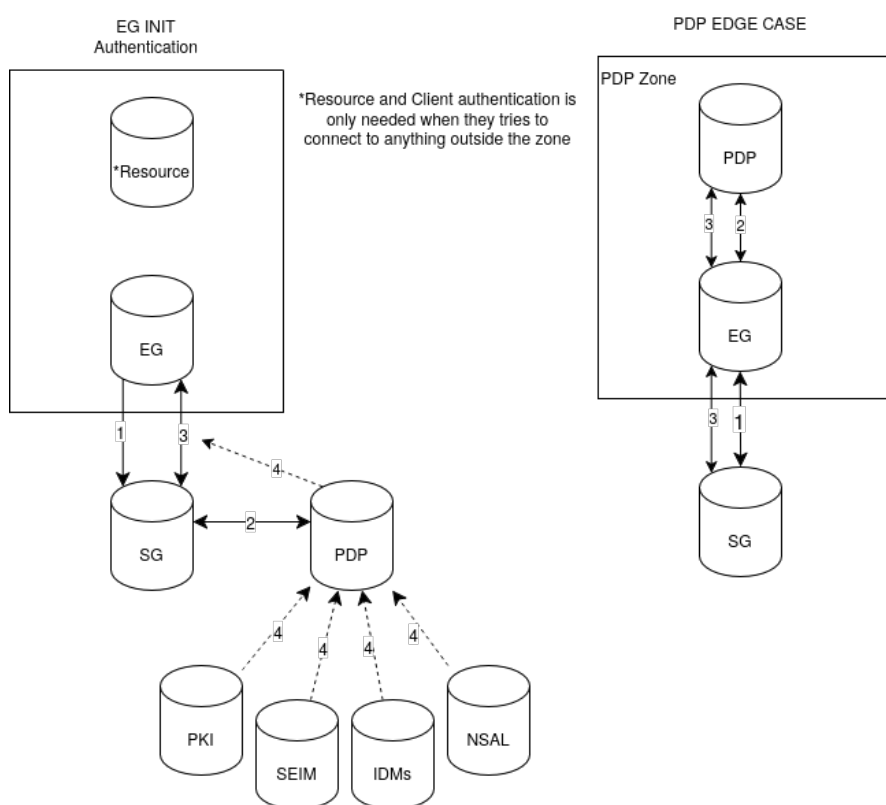
Figur 5.1: Ikoner som används i diagrammen

5.1 Kommunikationsflöden

Kommande figurer bygger på logiken i: Design; Kommunikationsflöden 4.3.4.

5.1.1 Initierande trafik

Vid uppstart av själva systemet så finns det inget sätt att SG kan verifiera autentiseringen mot PDP:s EG, då det inte finns någon anslutning mot PDP. Därför finns det ett förinstallerade certifikat för PDP:s EG i SG för att kunna skapa en initierande uppkoppling för att kunna ansluta resterande system. Om detta inte går att utföra eller att certifikatet inte stämmer överens så borde inte resterande system kunna sätta upp någon anslutning mot SG, alltså uppnås ett säkert tillstånd, enligt SFGK_FEL.

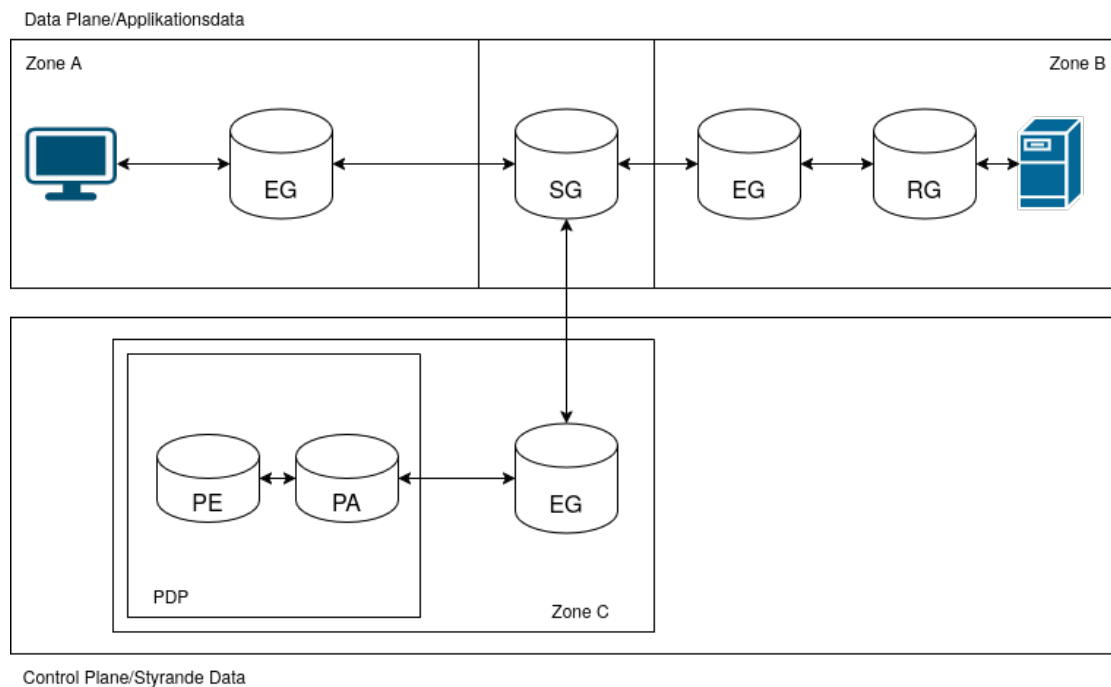


Figur 5.2: Initierande trafikflöde

5.1.2 Styrande- och Applikationsdata

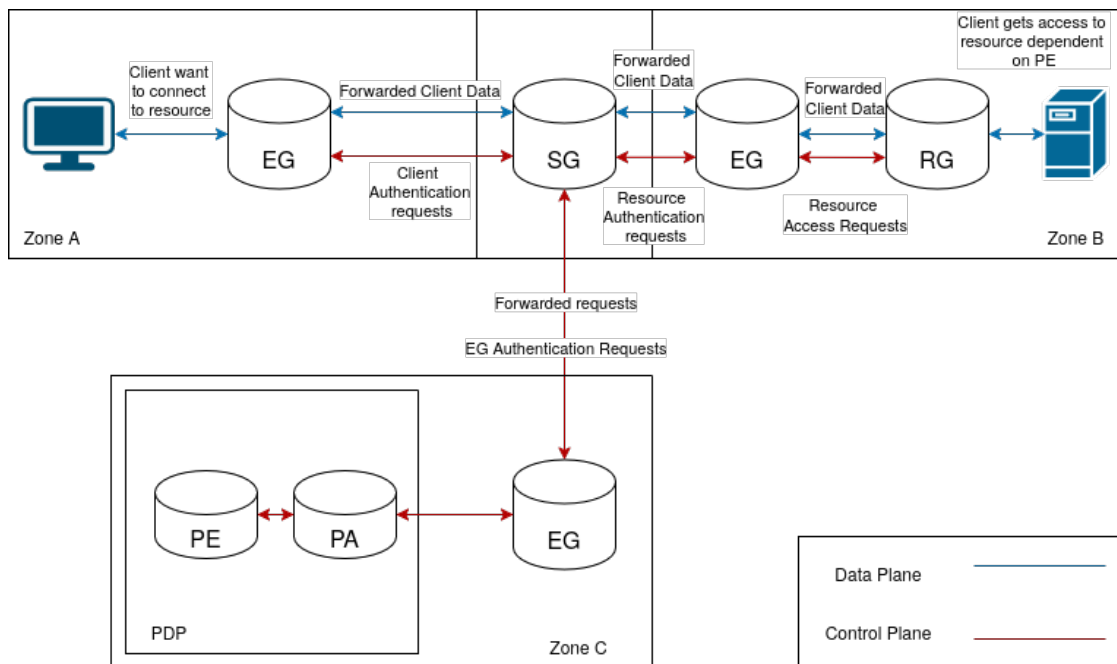
Figureerna illustrerar den logiska uppdelningen mellan Control Plane och Data Plane i praktiken.

I den abstrakta vyn visas hur applikationsdata flödar i Data Plane mellan subjekt och resurs via EG, SG och RG, medan styrande data flödar i Control Plane mellan EG och PDP. De två planen är logiskt separerade vilket innebär att en angripare som avlyssnar Data Plane inte kan påverka besluten i Control Plane.



Figur 5.3: Abstrakt vy av Styrande- och Applikationsdata

Den detaljerade vyn visar hur en åtkomstförfrågan faktiskt ser ut i praktiken. När ett subjekt i Zon A vill nå en resurs i Zon B vidarebefordras klientdata genom EG till SG, som skickar vidare autentiseringsförfrågningar till PDP i Control Plane. PDP fattar ett beslut och instruerar berörda PEP-noder, varefter applikationsdata kan flöda från SG via Zon B:s EG till RG och slutligen till resursen. EG spelar här rollen av att hantera kommunikation in och ut ur zonen, medan RG kontrollerar åtkomsten till specifika resurser inom zonen.

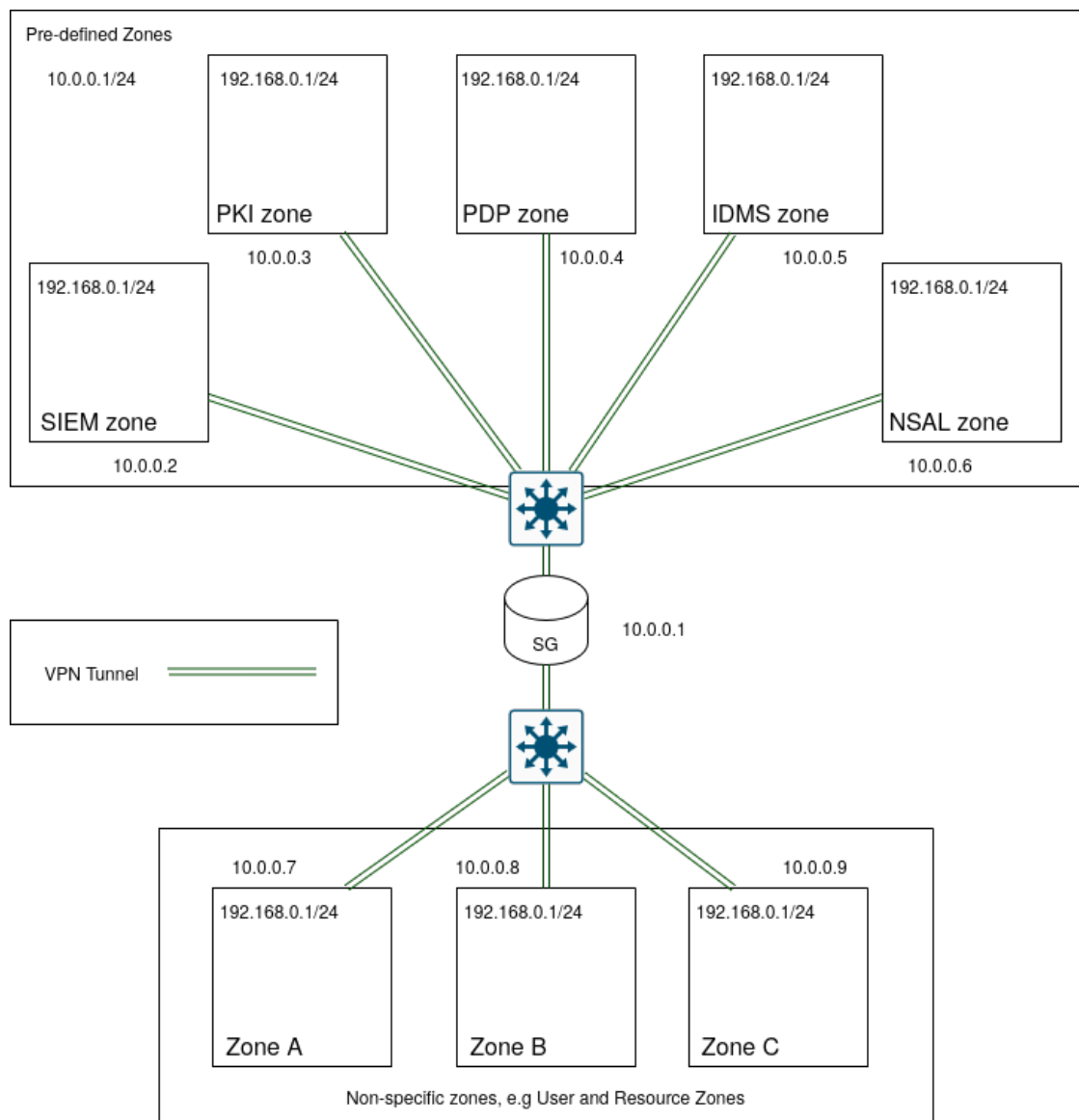


Figur 5.4: Detaljerad vy av Styrande- och Applikationsdata

5.2 Nätverkstopologi

Figur 5.5 presenterar den övergripande nätverkstopologin. SG placeras som den centrala knutpunkten i nätverket, där alla zoner ansluter via krypterade VPN-tunnlar. Nätverket är uppdelat i två kategorier av zoner; fördefinierade säkerhetszoner och icke-specifika zoner.

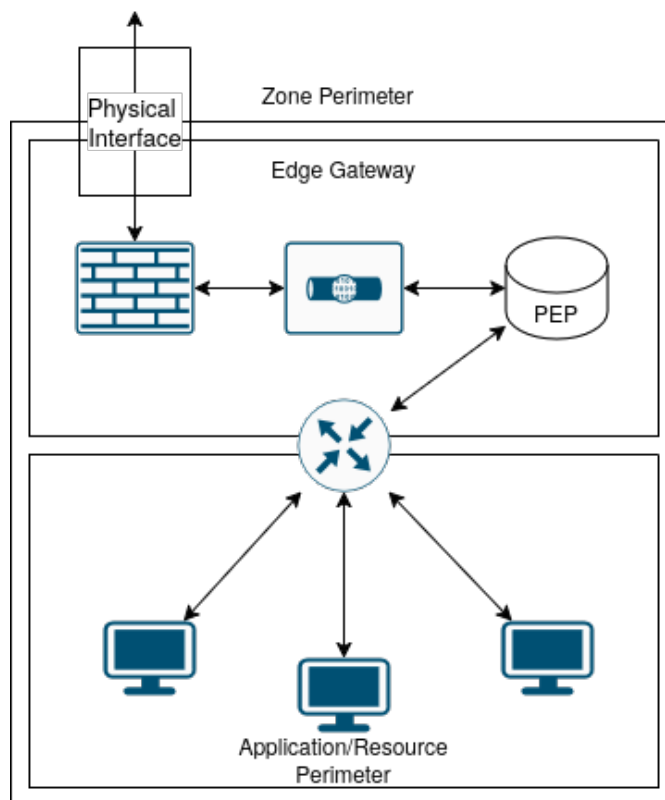
De fördefinierade zonerna utgörs av PKI, PDP, IDMS, SIEM och NSAL, dessa zoner tillhandahåller säkerhetsfunktioner och infrastruktur som krävs för att systemet ska fungera. De icke-specifika zonerna, exempelvis Zon A, B och C, representerar användare och resurser som varierar beroende på systemets användningsområde.



Figur 5.5: Nätverkstopologi

5.3 Zon-Struktur

Figur 5.6 illustrerar den interna strukturen hos en zon. Varje zon består av två logiska delar, Edge Gateway och Application Perimeter. Edge Gateway hanterar all kommunikation mellan zonen och SG via en krypterad VPN-tunnel, och innehåller en brandvägg som enbart tillåter VPN-trafik från SG.

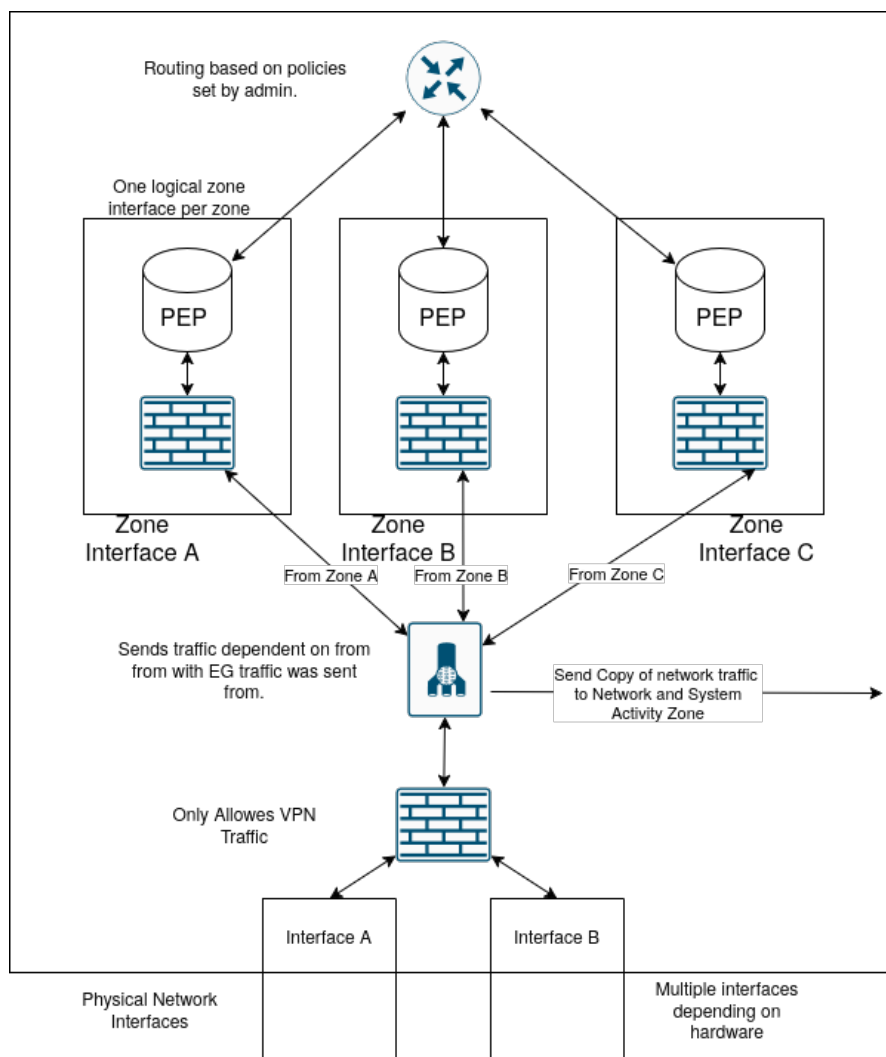


Figur 5.6: Zon och Edge Gateway

Application Perimeter är det interna nätverket där subjekt och resurser befinner sig. Från ett nätverksperspektiv behandlas Application Perimeter som ett eget isolerat nätverk, där kommunikation till andra zoner betraktas som extern trafik som måste passera genom Edge Gateway.

5.4 Segmentation Gateway

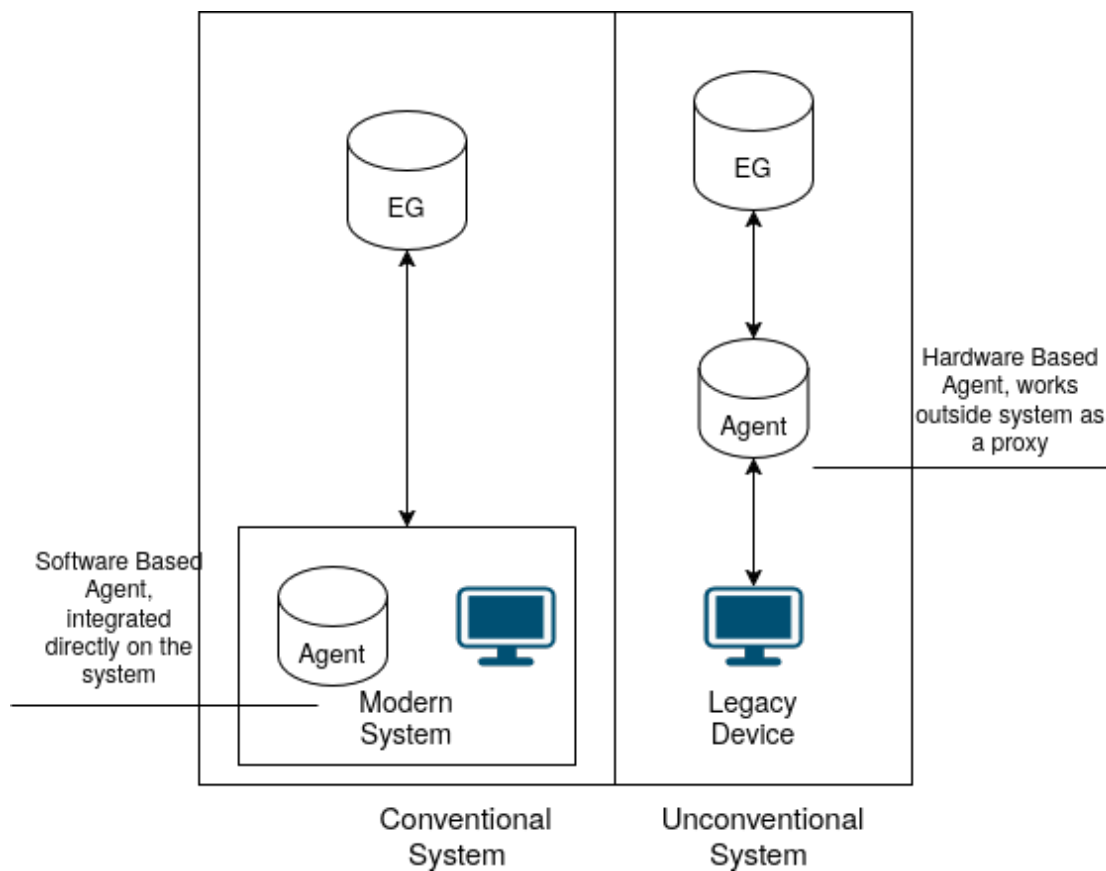
Figur 5.7 beskriver den logiska strukturen i Segmentation Gateway. Antalet fysiska interfaces kan variera utan att det påverkar modellen i sig. Antalet logiska interfaces beror på antalet zoner som existerar i nätverket, en per zon. Varje logisk interface behandlar och sätter brandväggsregler beroende på hur systemadministratören vill att de ska kommunicera, PEP hanterar den dynamiska kommunikationen där PDP bestämmer ifall trafik kan fortsätta flöda till zonen beroende på analyser från informationskällor.



Figur 5.7: Segmentation Gateway

5.5 Agentstruktur

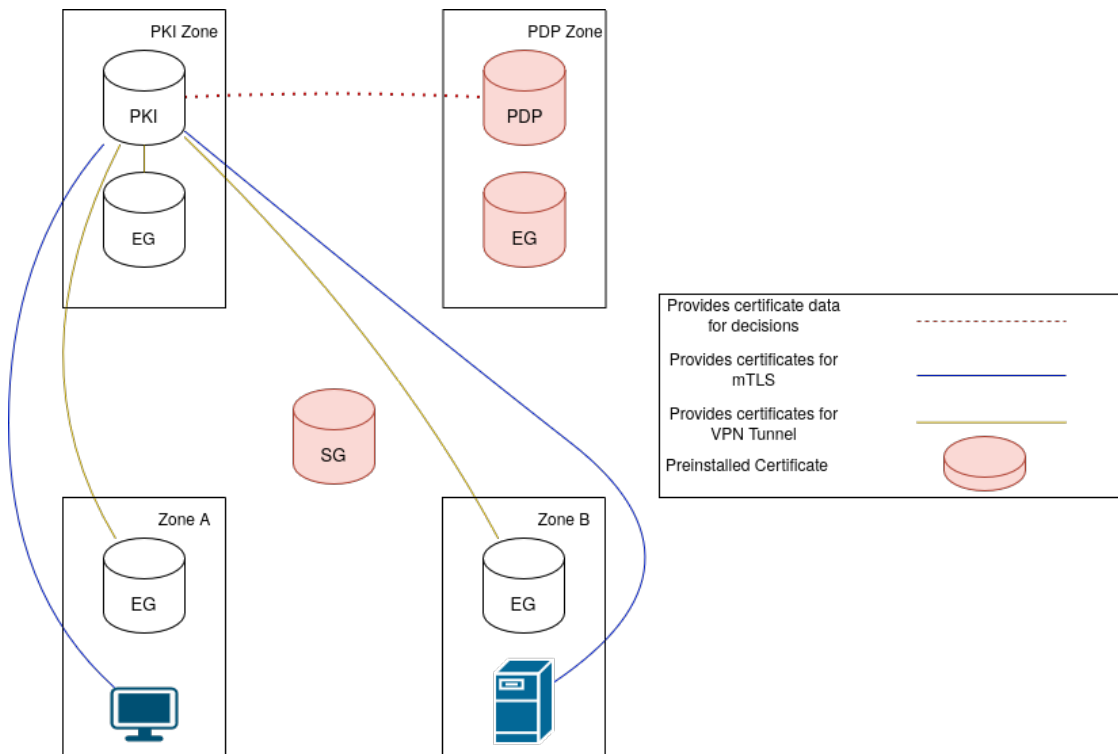
Figur 5.8 presenterar den ide som beskrivs i 4.3.3. De två olika modellerna bygger på vilken hårdvara subjekt har tillgång till, en för moderna system som ofta används av subjekt (Windows- och Linux-miljöer) och en för okonventionella system där hårdvaran inte själv kan utföra de säkerhetsmekanismer som krävs för att kunna skapa säkra sessioner till resurser.



Figur 5.8: Agentstruktur för Konventionella och Okonventionella system

5.6 PKI certifikat delegering

Figur 5.9 visar hur PKI delar ut certifikat till olika system i nätverket, detta representerar inte nätverksflöden utan visar i en abstrakt vy vilka system som tar emot certifikat från PKI.



Figur 5.9: PKI certifikat delegering

Observera att det finns vissa enheter med förinstallerade certifikat, detta är för att kunna först initiera trafiken, läs 4.3.4 om varför. Det är också viktigt, utöver vanlig mTLS och VPN trafik, att system kan efterfråga certifikat från PKI och att PDP godkänner denna trafik.

Kapitel 6

Slutsats

6.1 Diskussion

Detta kapitel kommer diskutera vilka krav som har uppfyllts och på vilket sätt de uppfyllts på.

6.1.1 KSF-kravuppfyllnad

Krav	Uppfylls av	Relevant Figur
Gemensamma krav (SFGK)		
SFGK_FEL	Om PDP, PEP, SG eller andra säkerhetsmekanismer är otillgänglig stängs all kommunikation	Figur 5.2

Tabell 6.1: Uppfyllda Gemensamma KSF krav

SFGK_FEL går ut på att system ska upprätta ett säkert tillstånd ifall säkerhetsmekanismer inte fungerar som det ska, detta översätts till att ingen kommunikation ska ske ifall säkerhetsfunktioner är ur drift.

Designen som presenteras i denna uppsats uppfyller detta kravet genom att kräva att alla PEP noder (SG, EG och RG) kräver att få svar från PDP för att kunna upprätta kommunikation mellan två punkter. Om inte PEP noder kan komma åt PDP så kan den inte upprätta någon session. Denna design presenteras i figur 5.2 där vi kan se att SG inväntar svar från PDP för att kunna upprätta en session med EG.

Krav	Uppfylls av	Relevant Figur
Behörighetskontroll (SFBK)		
SFBK_AUT	mTLS och VPN via PKI, PDP kan återkalla aktiva sessioner	Figur 5.9 och 5.4
SFBK_ÅTK	RBAC/ABAC via IDMS, åtkomstkontroll via PEP	Figur 5.4

Tabell 6.2: Uppfyllda Behörighetskontroll KSF krav

SFBK_AUT och SFBK_ÅTK ställer krav på att varje subjekt autentiseras innan åtkomst ges, att säkerhetsattribut skyddas under lagring och transport, samt att pågående sessioner avslutas omedelbart vid revokering av behörighet.

Autentiseringskraven i SFBK_AUT uppfylls primärt genom mTLS, som kräver att båda parter i en kommunikation presenterar giltiga certifikat utfärdade av den interna PKI-tjänsten. Detta innebär att varje subjekt och komponent autentiseras innan en session kan upprättas, och att trafiken samtidigt skyddas från obehörig avläsning och manipulation under transport. Kravet på att pågående sessioner ska avslutas vid revokering hanteras av PDP, som kontinuerligt övervakar aktiva sessioner och kan avbryta dessa omedelbart om ett certifikat återkallas eller om avvikande beteende detekteras.

Åtkomstkontrollkraven i SFBK_ÅTK uppfylls genom RBAC och ABAC via IDMS, där varje subjekts identitet är kopplad till specifika rättigheter och roller. PEP-noderna (EG, SG och RG) utgör flera lager av åtkomstkontroll där varje förfrågan utvärderas av PDP innan kommunikationskanalen öppnas. RG, som placeras direkt framför resursen, utgör det sista och mest detaljerade lagret där RBAC- och ABAC-regler tillämpas fullt ut. Figur 5.4 presenterar detta bäst genom att visa varje PEP nod frågar PDP om sessionen kan upprättas genom att autentisera subjektet som vill upprätta sessionen, PDP inte bara autentiserar subjektet utan också kollar ifall subjektet har åtkomst till det den vill komma åt. Detta kan avgöras då PDP får denna information från IDMS.

Krav	Uppfylls av	Relevant Figur
Intrångsdetektering (SFID)		
SFID_DAT	All trafik passerar SG och loggas till NSAL-zonen	Figur 5.7
SFID_ANA	SIEM-system i loggzonen, koppling till Kindstedts arbete	Figur 5.5

Tabell 6.3: Uppfyllda Intrångsdetektering KSF krav

SFID_DAT och SFID_ANA ställer krav på att systemet samlar in både system- och nätverksloggar till en gemensam analys- och detekteringsfunktion, samt att denna funktion kan detektera avvikelser i både kända och okända attackmönster.

SFID_DAT uppfylls genom att all trafik mellan zoner tvingas passera SG, vilket innebär att nätverksmetadata genereras och samlas in centralt för all kommunikation i systemet. Utöver nätverksloggar samlas system- och applikationsloggar från samtliga zoner och vidarebefordras till den dedikerade loggzonen NSAL. NSAL är skrivskyddad från övriga zoner, vilket innebär att ingen komprometterad zon kan manipulera eller radera befintliga loggar ett krav som egentligen definieras under SFSL_SKY men som är en

förutsättning för att loggarna ska vara tillförlitliga som underlag för detektering.

SFID_ANA uppfylls av SIEM-systemet i loggzonen, som kontinuerligt analyserar insamlade händelser och kan detektera avvikelser baserat på både kända attackmönster och onormalt beteende. En viktig egenskap i designen är att SIEM är integrerat med PDP, vilket innebär att detekterade avvikelser inte enbart genererar en varning utan aktivt kan påverka åtkomstbeslut i realtid, exempelvis genom att en pågående session avslutas omedelbart.

Det kan vara värt att nämna att avgränsning om specifika implementationen av logganalys, inklusive eventuell AI-baserad avvikelседetektering, behandlas i Kindstedts arbete och faller utanför denna uppsats. Designen definierar den arkitekturella placeringen och integrationen av SIEM-systemet, men inte dess interna analyslogik.

Krav	Uppfylls av	Relevant Figur
Intrångsskydd (SFIS)		
SFIS_INT	mTLS och Site-to-Site VPN-tunnlar mellan EG, SG, subjekt och resurser	Figur 5.9, 5.5 och 5.4
SFIS_KIN	SG inspekterar inkommande trafik, enbart autentiserade EG accepteras	Figur 5.7 och 5.2
SFIS_KUT	SG filtrerar utgående trafik via brandväggsregler	Figur 5.7

Tabell 6.4: Uppfyllda Intrångsskydd KSF krav

SFIS_INT, SFIS_KIN och SFIS_KUT ställer krav på att kommunikation mellan system skyddas mot obehörig åtkomst och manipulation, att inkommande trafik kontrolleras och filtreras, samt att utgående trafik begränsas till det som är strikt nödvändigt.

SFIS_INT uppfylls primärt genom mTLS, som säkerställer att båda parter autentiseras och att trafiken krypteras innan någon dataöverföring sker. I de fall där mTLS inte är applicerbart, exempelvis vid filöverföring, används alternativa säkra protokoll som SFTP i stället för okrypterade alternativ. Man kan också se det på de sättet att man väljer bort alternativ som inte har stöd för mTLS

SFIS_KIN och SFIS_KUT adresseras av SG, som fungerar som den centrala kontrollpunkten för all trafik mellan zoner. Eftersom all trafik mellan zoner tvingas passera genom SG kan brandväggsregler tillämpas konsekvent för att filtrera både inkommande och utgående trafik. Mikrosegmenteringen förstärker detta ytterligare, en zon är per design enbart tillåten att kommunicera med de zoner som är strikt nödvändiga för dess funktion, vilket begränsar möjligheten till lateral movement om en zon komprometteras.

Krav	Uppfylls av	Relevant Figur
Säkerhetsloggning (SFSL)		
SFSL_REG	Alla händelser loggas via NSAL i dedikerad loggzon	Ingen relevant figur
SFSL_SKY	NSAL-zonen är skrivskyddad, ingen zon kan modifiera loggar	Ingen relevant figur
SFSL_ANA	SIEM analyserar händelser och integreras med PDP i realtid	Figur 5.2

Tabell 6.5: Uppfyllda Säkerhetsloggning KSF krav

SFSL_REG, SFSL_SKY och SFSL_ANA ställer krav på vilka säkerhetshändelser som ska loggas, att dessa loggar inte kan manipuleras eller raderas, samt att det finns ett system som kontinuerligt analyserar dem.

Det är värt att påpeka att designen inte i detalj specificerar hur varje enskilt system ska implementera sin loggning internt. Istället utgår designen från att de olika komponenterna och zonerna (PDP, EG, RG och övriga system) på egen hand genererar och vidarebefordrar relevanta säkerhetshändelser till SIEM och NSAL.

SFSL_SKY uppfylls strukturellt genom att NSAL-zonen är skrivskyddad från övriga zoner, ingen komprometterad zon kan modifiera eller radera befintliga loggar.

SFSL_ANA uppfylls av SIEM-systemet, som är samma komponent som adresserar SFID_ANA. SIEM analyserar händelser lagrade i NSAL och detekterar avvikelser baserat på både kända och okända attackmönster. Integrationen med PDP innebär att analysresultat inte bara genererar varningar utan aktivt kan påverka åtkomstbeslut i realtid.

6.1.2 Always Verify

Always Verify innefattar att man alltid ska kontinuerligt verifiera och autentisera all trafik mellan två parter. I denna modell så identifieras primärt tre metoder för att kunna uppnå detta.

1. All kommunikation mellan subjekt och resurs ska autentiseras från båda håll, detta görs primärt med mTLS.
2. All kommunikation mellan zoner ska autentiseras mot SG, detta sker via VPN tunnlar med SG som agerar VPN server.
3. All kommunikation övervakas och granskas av PEP noder som agerar mellanhand under kommunikationsflöden, dessa upprättar och hanterar sessioner utefter beslut från PDP i realtid.

6.1.3 Least Privilege

Least Privilege innefattar att minimera åtkomstprivileger till resurser och behörigheter för system till enbart de behöver ha tillgång till. Denna uppfylls på två nivåer i denna design.

1. *Nätverksnivå*: Genom mikrosegmentering så begränsar man kommunikationen mellan olika zoner till enbart den kommunikationen som krävs för att system ska kunna fungera. Detta utgår från att varje zon enbart innefattar relaterade system, exempelvis en resurs med tillhörande databas.
2. *Systemnivå*: Detta uppnås via implementering av RBAC och/eller ABAC kopplat till ett IDMS system, varje subjekt måste ha korrekta behörigheter för att komma åt resurser. PEP noder, som är noggrant utplacerade framför resurser eller zoner, är där reglerna från IDMS tillämpas innan åtkomst ges till subjekt. RG som är placerade just framför resurser, hanterar åtkomst till just resurser, medan EG hanterar åtkomst till zoner.

6.1.4 Assume Breach

I *Assume Breach* så utgår designen från att intrång kommer att ske. Detta uppfylls i flera designval:

1. Nätverk- och systemloggar skickas till NSAL zonen för att senare analyseras av SIEM för att granska säkerhetsrisker, så PDP kan utföra bättre beslut.
2. Mikrosegmentering gör det mycket enklare att isolera specifika zoner vid detekterade avvikelser.
3. NSAL-zonens skrivskyddade natur innebär att en angripare inte kan manipulera eller radera loggar för att dölja sin närvaro.

6.1.5 Svagheter, Risker och Begränsningar

Det finns vissa svagheter och risker i designen som kan riskera tillgänglighet och vissa sårbarheter i system. Då PDP zonen fungerar som en central beslutsfattande punkt, då kan tillgängligheten i systemet riskeras ifall PDP zonen blir överflödad av förfrågningar, samma gäller ifall den skulle sluta fungera helt. Detta är ett medvetet designval, för att följa SFGK_FEL, men kan fortfarande orsaka problem i resterande av systemet. Detsamma gäller SG, då den fungerar som en knutpunkt mellan alla zoner.

Ytterligare så finns det risker ifall PEP, PDP eller SG blir komprometterad, alltså att en angripare lyckas komma åt systemet i någon form. Designval relaterade till Zero Trust ska göra så att detta blir svårt, men man måste fortfarande räkna med att det kan hända. Designen presenterar en idé om att komprometterad system enbart kan störa trafik (avsluta sessioner och/eller vidarebefordra trafik) eller avlyssna krypterad trafik, därför är valet av just mTLS och VPN trafik viktigt i detta fall. Om en PEP nod blir komprometterad så kommer den enbart kunna se den krypterade trafiken mellan två system, då det sker i någon form två lager av kryptering, en mellan subjekt och resurs, sen en mellan EG och SG.

Den stora risken och begränsningen i denna design kommer ifall PKI skulle bli komprometterad, vilket denna design inte direkt har någon lösning för utöver de säkerhetsmekanismerna som redan existerar för de andra zonerna. Riskerna som kommer ifall PKI blir komprometterad och kommer åt nyckelparen för alla certifikat blir att mTLS och VPN tunnlarna blir värdelösa, då angripare kan dekryptera trafiken eller låtsas vara resursen/subjektet i fråga. Det kan vara värt att kolla på eventuella säkrare möjligheter hos PKI, som exempelvis en offline CA (se 6.3.3).

6.2 Slutsats

Frågan som denna uppsats försökte svara på var *Hur applicerar man Zero Trust principer och Försvarsmaktens KSF i en isolerad komplex miljö?*. Denna uppsats diskuterar, tolkar och applicerar både KSF kraven och Zero Trust principerna i en design som försöker applicera dessa i ett realistiskt perspektiv. Slutsatsen av denna uppsats är att det går att applicera Zero Trust principer tillsammans med Försvarsmaktens KSF i isolerade komplexa miljöer.

6.3 Vidare arbete

6.3.1 PoC

För att realisera den framtagna designen föreslås en proof-of-concept (PoC) implementeras i steg, där varje steg bygger på föregående.

Steg 1 Kärninfrastruktur: SG och EG

SG och EG är de komponenter som är viktigast i denna design, då dessa gör det möjligt att kommunicera mellan zoner. Utifrån ett utvecklarperspektiv så kommer man inte kunna utföra några konkreta beslut om anslutningar innan man har integrerat PDP, men det viktigaste är att få dessa att kunna kommunicera på ett säkert sätt.

Steg 2 Integration mot PDP, PKI, IDMS och andra informationskällor

När SG och EG fungerar integreras de mot övriga säkerhetszoner. Det finns redan existerande alternativ för dessa komponenter som redan används flitigt. Valet av specifika produkter för dessa komponenter lämnas till systemadministratören, förutsatt att de stödjer de integrationsgränssnitt som SG och EG förväntar sig.

Steg 3 Agenter

Med grundinfrastrukturen på plats kan mjukvarubaserade agenter för konventionella system utvecklas. Agenten, autentiserar systemet mot EG via mTLS och samlar in systeminfo till PDP:s Policy Engine. För okonventionella och legacy-system utvecklas en hårdvarubaserad lösning som agerar fysisk proxy mellan legacy-enheten och nätverket, och hanterar mTLS utåt oberoende av vad legacy-enheten själv stödjer.

Steg 4 Resource Gateway

Som sista steg implementeras RG, som placeras framför individuella resurser inom en zon och utgör den sista PEP-noden innan trafiken når resursen. Till skillnad från EG, som hanterar zon-till-zon-kommunikation, hanterar RG kommunikationen från subjekt till resurs och ställer därmed mer detaljerade förfrågningar mot PDP där RBAC- och ABAC-regler tillämpas fullt ut.

6.3.2 Tolka System-av-System enligt KSF

KSF definierar att system-av-system, alltså de olika komponenterna som presenteras i Figur 5.5 och 4.2 ska tolkas enskilt ifrån denna generaliserade analysen som presenteras i denna uppsats, vilket innebär att den generaliserade design som presenteras i denna uppsats utgör en arkitekturell grund snarare än en färdig lösning. Vid en konkret driftsättning behöver varje komponent, exempelvis SG, EG och PDP, genomgå en individuell KSF-analys. Detta kan innebära att vissa komponenter ställer högre krav på tillgänglighet, loggning eller isolering än vad den generaliserade analysen förutsätter.

6.3.3 PKI och offline certifikatutfärdare

Problemet med PKI och certifikatutfärdare som presenteras i 6.1.5 beskriver att PKI och CA är en *single-point-of-failure*. Det kan vara värt att vidareutveckla denna modell

för att inkludera responshantering rutiner och gå mer in på en teknisk nivå på hur man kan säkra denna zon på ett bättre och detaljerat sätt än vad denna uppsats presenterar. En möjlig förbättring är att använda en offline root CA, där rotnyckeln hålls helt fysiskt isolerad och enbart används för att signera underliggande intermediate CA:er. Den dagliga certifikatutfärdningen hanteras då av en online intermediate CA, vilket innebär att ett fjärrangrepp mot rotnyckeln blir omöjligt, fysisk tillgång krävs. Detta reducerar attackytan avsevärt.

Litteraturförteckning

- [1] Cloudflare. What is mTLS? Hämtad 2026-05-04.
- [2] John Kindervag et al. Build security into your networks DNA: The zero trust network architecture. *Forrester Research Inc*, 27, 2010. Hämtad: 2026-04-23.
- [3] Scott Rose, Borchert Oliver, Mitchell Stu, and Connelly Sean. Zero Trust Architecture. *NIST*, 2020. Hämtad: 2026-05-04.
- [4] Försvarsmaktens Högkvarter. KSF; Krav på IT-säkerhetsförmågor hos IT-system, 2014-06-13. Hämtad 2026-02-19.
- [5] Check Point Team. Global Cyber Attacks Rise in January 2026 Amid Increasing Ransomware Activity and Expanding GenAI Risks. Hämtad 2026-03-06.
- [6] Cloudflare. What is a Zero Trust network? Hämtad 2026-02-25.
- [7] John Kindervag, S Balaouras, K Mak, and J Blackborow. No more chewy centers: The zero trust model of information security. *Forrester Research*, 23, 2016. Hämtad: 2026-04-23.
- [8] Muhammad Raza. What is ABAC? Attribute Based Access Controls, Explained. Hämtad 2026-03-09.
- [9] CISA. What Is Cybersecurity?, 2021. Hämtad 2026-05-25.

[10] Fortinet. What Is Microsegmentation? Hämtad 2026-05-22.

[11] Laiba Siddiqui. RBAC: Role-Based Access Controls, Explained. Hämtad 2026-03-09.

Bilagor

Bilaga A

Bilagor från KSF

...

A.1 Tabell för konsekvensnivå

Gradering	Generell konsekvensbeskrivning samt konsekvensbeskrivning vid informationsförlust av sekretessklassificerade uppgifter.	Konsekvensbeskrivning avseende informationsförlust av hemliga eller utrikesklassificerade uppgifter
[5] Synnerligen allvarligt	Förväntade konsekvenser medför en synnerlig negativ effekt. Konsekvenserna innebär synnerligen allvarliga negativa effekter av stor omfattning, under lång tid och utgör ett direkt hot mot organisationen. Konsekvenserna är inte begränsade till enstaka förmågor eller funktioner inom organisationen.	Hemliga uppgifter vars röjande kan medföra synnerligt men för totalförsvaret eller förhållandet till en annan stat eller en mellanfolklig organisation eller i annat fall för rikets säkerhet (kvalificerat hemliga uppgifter). Hemlig handling som har åsatts beteckningen TOP SECRET eller motsvarande av en utländsk myndighet eller mellanfolklig organisation.
[4] Allvarlig	Förväntade konsekvenser är betydande. Konsekvenserna är allvarliga, av stor omfattning eller av väsentlig art och innebär ett direkt hot, om än mot avgränsade förmågor eller funktioner inom organisationen.	Hemliga uppgifter vars röjande kan medföra betydande men för totalförsvaret eller förhållandet till en annan stat eller en mellanfolklig organisation eller i annat fall för rikets säkerhet. Hemlig handling som har åsatts beteckningen SECRET eller motsvarande av en utländsk myndighet eller mellan- folklig organisation.

Gradering	Generell konsekvensbeskrivning samt konsekvensbeskrivning vid informationsförlust av sekretessklassificerade uppgifter.	Konsekvensbeskrivning avseende informationsförlust av hemliga eller utrikesklassificerade uppgifter
[3] Kännbar	Förväntade konsekvenser är inte obetydliga och äventyrar, vållar skada, hindrar, underlättar, innebär större avbrott samt medför påtagliga negativa effekter om än i begränsad omfattning	Hemliga uppgifter vars röjande kan medföra ett inte obetydligt men för totalförsvaret eller förhållandet till en annan stat eller en mellanfolklig organisation eller i annat fall för rikets säkerhet. Hemlig handling som har åsatts beteckningen CONFIDENTIAL eller motsvarande av en utländsk myndighet eller mellanfolklig organisation.
[2] Lindrig	Förväntade konsekvenser är ringa och begränsas till att påverka, försvåra, hindra, undergräva, misskreditera eller störa verksamheten i mindre omfattning.	Hemliga uppgifter vars röjande kan medföra endast ringa men för totalförsvaret eller förhållandet till en annan stat eller en mellanfolklig organisation eller i annat fall för rikets säkerhet. Hemlig handling som har åsatts beteckningen RESTRICTED eller motsvarande av en utländsk myndighet eller mellanfolklig organisation.
[1] Försumbar	Konsekvenser för verksamheten är försumbara.	Uppgifter är inte hemliga eller utrikesklassificerade.

Tabell A.1: Bedömning av konsekvens enligt femgradig skala; Konsekvensnivå från KSF[4]

A.2 Tabell för exponeringsnivå

Tabellen för exponeringsnivå har vissa begrepp förtydligat i dokumentet för KSF, läs där för en komplett vy över exponeringsnivån. Förekommande information i tabellen kommer från KSF.

Exponeringsnivå	Tillgång till systemets fysiska och logiska gränssytor.		Informationsutbyte
E4	<i>Alla fall som inte uppfyller kriterierna för någon av exponeringsnivå E1-E3 nedan.</i>		Alla fall som inte uppfyller kriterierna för någon av exponeringsnivå E1-E3 nedan.
E3	Alla personer med tillgång till någon av systemets gränssytor är säkerhetsprövade.	och	Samtliga system som systemet utbyter information med är ackrediterade till en högre konsekvensnivå eller Samtliga system som systemet utbyter information med är ackrediterade till samma konsekvensnivå med högst exponeringsnivå E3.
E2	Alla personer med tillgång till någon av systemets gränssytor är behöriga till <u>någon information</u> inom den högsta konsekvensnivån som behandlas i systemet.	och	Samtliga system som systemet utbyter information med är ackrediterade till en högre konsekvensnivå eller Samtliga system som systemet utbyter information med är ackrediterade till samma konsekvensnivå med högst exponeringsnivå E2.
E1	Alla personer med tillgång till systemets gränssytor är behöriga till <u>all information</u> som behandlas i systemet.	och	Systemet utbyter ingen information med andra system.

Exponeringsnivå	Tillgång till systemets fysiska och logiska gränssytor.		Informationsutbyte
------------------------	--	--	---------------------------

Tabell A.2: Exponeringsnivåer med tillhörande kriterier; Exponeringsnivåer från KSF[4]

A.3 Tabell för kravnivå

Grund = G; Utökad = U; Hög = H.

	Exponeringsnivå			
Konsekvensnivå	E1	E2	E3	E4
5	H	H	H	H
4	U	H	H	H
3	U	U	U	H
2	G	U	U	U
1	G	G	G	G

Tabell A.3: Fastställning av kravnivå; Kravnivå från KSF[4]

A.4 Kravstruktur



Figur A.1: Exempel på kravidentifiering utifrån KSF[4]

A.5 Funktionella säkerhetskrav

Kommande tabell presenterar varje funktionellt säkerhetskrav som finns i KSF, det kommer inte betyda att alla krav kommer nödvändigtvis vara applicerbara i detta arbete. KSF går tydligare in på varje krav och dess korresponderande kravnivå och kravkomponenter, om förtydligande i säkerhetskraven efterfrågas så hänvisas de till KSF. Tolkningar och filtrering av funktionella säkerhetskrav förekommer i sektion 3.

A.5.1 Tabell för Funktionella Säkerhetskrav

Krav	Beskrivning
Gemensamma krav (SFGK)	
SFGK_FEL	Säkerhetsfunktioner ska kunna upprätthålla ett säkert tillstånd vid fel
SFGK_TID	Säkerhetsfunktionen ska använda systemets gemensamma tid
Behörighetskontroll (SFBK)	
SFBK_UID	Subjekt ska ha en unik identitet

Krav	Beskrivning
SFBK_AUT	Autentisering av subjekt ska ske
SFBK_ÅTK	Subjekt ska endast ges åtkomst till objekt som de är behöriga till
SFBK_ADM	Administration av behörighetskontroll ska ske på ett säkert sätt
Intrångsdetektering (SFID)	
SFID_DAT	Information från relevanta datakällor ska vara tillgängliga för analys
SFID_ANA	Intrång och missbruk ska kunna upptäckas och spåras
Intrångsskydd (SFIS)	
SFIS_HRD	Systemets komponenter ska härdas mot intrång
SFIS_INT	Kommunikation ska skyddas mot otillbörlig åtkomst och manipulation
SFIS_KIN	Information som passerar in genom systemets gränssytor ska kontrolleras
SFIS_KUT	Information som flödar ut ur systemet ska kontrolleras
Skydd mot skadlig kod (SFSK)	
SFSK_UPD	Funktioner för hantering av säkerhetsuppdateringar ska finnas
SFSK_RIK	Riktighetskontroll av mjukvara och konfigurationer ska vara möjlig
SFSK_EXE	Endast godkänd mjukvara ska kunna exekvera i systemet
SFSK_KUT	Skadlig kod ska ej kunna spridas via systemet
SFSK_KIN	Skadlig kod ska ej kunna föras in i systemet
Säkerhetsloggning (SFSL)	
SFSL_REG	Säkerhetsrelaterade händelser ska registreras
SFSL_OAV	Användare ska kunna göras individuellt ansvariga för sina åtgärder
SFSL_SKY	Säkerhetsloggar ska ej kunna förvanskas eller förstöras
SFSL_ANA	Säkerhetsloggar ska analyseras för att upptäcka intrång och missbruk
Skydd mot röjande signaler (SFRS)	

Krav	Beskrivning
SFRS_REG	RÖS krav från gällande regelverk ska uppfyllas
Skydd mot obehörig avlyssning (SFOA)	
SFOA_KBL	Hemliga uppgifter i elektroniska kommunikationsnät ska skyddas

Tabell A.4: Alla funktionella säkerhetskrav från KSF[4]